加雲聯網股份有限公司

SI-SM Project Security Management Planning Guideline

整合/維護服務專案安全管理規劃指南

版　別：1.0

制訂日期：2024 年 01 月 18 日

修訂日期：2024 年 01 月 18 日

制修部門：XX 室

頁　數：X

核准	審查	制定

文件發行/修訂記錄

版次	發行日期	生效日期	制修內容摘要
1.0	2024/05/31	2024/05/31	新建

Content

1.0 Object 目的 4
1.1 簡介 Introduction 4
1.2 本文件的目的和目標 Purposes and Objectives of This Document 4
2.0 Scope 適用範圍 5
2.1 本文件範圍 Scope of This Document 5
2.2 適用性和有效性 Applicability and Validity 5
2.2.1 適用性 Applicability 5
2.2.2 有效性 Validity 6
3.0 Responsibility 責任 6
4.0 Definitions 名詞定義 6
5.0 Instructions 作業說明 10
5.1 安全系統整合/維護服務專案概述 Secure SI/SM Project Overview 10
5.1.1 專案概述 Project Overview 10
5.1.2 系統或 IACS 自動化解決方案概述 System or IACS Automation Solution Overview ... 10
5.2 安全政策與管理理念 Security Policy and Management Philosophy 11
5.2.1 安全政策 Security Policy 11
5.2.2 安全管理理念 Security Management Philosophy 11
5.3 安全保證組織 Security Assurance Organization 13
5.3.1 專案安全保證組織 Project Security Assurance Organization 13
5.3.2 角色與責任 Roles and Responsibility 15
5.3.3 能力要求 Competency Requirements 19
5.3.4 其他相關計畫的介面管理 Management of Interfaces with Other Relevant Programs 20
5.4 安全績效目標與要求 Security Performance Targets and Requirements 21
5.4.1 風險分類矩陣 Risk Classification Matrix 21
5.4.2 安全目標 Security Targets 22
5.4.3 最低合理可行原則 ALARP Principle 23
5.4.4 安全要求 Security Requirements 23
5.5 安全計畫和任務 Security Program and Activities 24
5.5.1 安全整合/維護服務專案生命週期 Secure SI/SM Project Lifecycle 24
5.5.2 專案安全任務和/或活動 Project Security Tasks and/or Activities 25
5.5.3 專案安全保證產出文件和時間表 Project Security Assurance Deliverables and Schedule 32
5.5.4 服務水準協議/協定 Service Level Agreement (SLA) Protocol 36
5.6 安全保證方法 Secure Assurance Approach 36
5.6.1 一般原則 General Principles 36
5.6.2 安全基線要求和控制措施 Baseline Security Requirements and Control Measures ... 37
5.6.3 安全保證流程 Security Assurance Processes 37
5.6.4 安全研討 Security Studies 39
5.6.5 網宇威脅和漏洞日誌 Cyber Threats and Vulnerability Log 42
5.6.6 安全關鍵要素、要求和清單 Security Critical Elements, Requirements, and List 42

5.6.7 網宇威脅管理系統 Cyber Threats Management System 43
5.7 安全保證管理 Security Assurance Management 43
5.7.1 品質管理 Quality Management 43
5.7.2 安全管理 Security Management 43
5.7.3 安全審查、稽核和評鑑 Security Reviews, Audits, and Assessment 44
5.8 使用表單 Proforma Table Use： 46
6.0 Appendix 附件 53
7.0 Reference 70

1.0 Object 目的

1.1 簡介 Introduction

This document describes the required works scope and the implementation methods or processes of IACS Automation Solution for OT Security Requirements for dummy project's OT Security for an Integration/Maintenance Service Project (SI/SM Project) in accordance with the requirements specified for a Secure SI/SM Project during its Secure-by-design framework and lifecycle. It provides analytic, scientific, and systematic methods and management processes for implementing SI/SM Project security activities in order to ensure the compliance with the relevant SI/SM Project security requirements. It also provides guidance information for a Secure SI/SM Project during its Secure-by-design framework and lifecycle to establish its security management plan.

1.2 本文件的目的和目標 Purposes and Objectives of This Document

Systems' or IACS Automation Solutions' Security refers to the activities required to demonstrate that a System or IACS Automation Solution is fit for the purpose of providing its functionality, as defined in a Secure SI/SM Project security design criterion, in a secure manner. This document will provide the implementation requirements of the System security and ensure its security in a systematic and logical manner. It provides the security requirements of a Secure SI/SM Project that will be considered and achieved throughout the duration of a Secure SI/SM Project lifecycle, and that any modification required as a result is included in the Concept/Specification (R0/R1), Development/Design and Development (R2), and Production/Implementation and Verification and Validation (R3) stages.

The purpose of this document will be:

1 To describe a Secure SI/SM Project security policy and responsibilities undertaken by the ICP's Project team in accordance with the Secure SI/SM Project security requirements;

2 To set out a Secure SI/SM Project security program for activities to be undertaken by the ICP'S Project team throughout the Secure SI/SM Project lifecycle to ensure the security of the System or IACS Automation Solution; and

3 To provide an analytic, scientific and management method or process for implementing the Secure SI/SM Project security activity in order to ensure compliance with the System or IACS Automation Solution security requirements.

The objectives of this document will be:

1 To describe the strategy, approach and method or process of a System or IACS Automation Solution security analysis to be performed;

2 To provide the security targets and to define the security targets acceptance criteria;

3 To describe the Secure SI/SM Project security assurance organization to management a System or IACS Automation Solution security activities during the Secure SI/SM Project lifecycle;

4 To specify the responsibilities for the management of a Secure SI/SM Project security

activities; and

5 To describe how the security targets will be verified during the Secure SI/SM Project lifecycle.

2.0 Scope 適用範圍

2.1 本文件範圍 Scope of This Document

This document describes SI/SM Project security activities to be carried out by the ICP's Project team from a System level perspective. These activities should be programmed to fulfil the Secure SI/SM Project security requirements specified by

1 the System or IACS Automation Solution Users;
2 the Asset Owner;
3 the Customer or Client;
4 the applicable regulations, standards, code, and practices; or
5 the ICP's Project team, which derived from security risk assessments.

This document shall be applied to the ICP's Project team to develop their suitable security assurance activities, and to fulfil Systems' or IACS Automation Solutions' security requirements specified in the reference guidelines.

This document provides a guideline for a Secure SI/SM Project planning to cover the following subjects:

1 The objectives, purpose, scope and the used standards and/or practices of an SI/SM Project Security Management Plan;
2 How security organization and a Secure SI/SM Project security management being integrated into the Concept/Specification (R0/R1), Development/Design and Development (R2), and Production/Implementation and Verification and Validation (V&V) (R3) project life cycle stages;
3 The internal and external interfaces between SI/SM Project security activities, and the management of interfaces with other programs;
4 The approach, methods, processes to conduct SI/SM Project security activities throughout a Secure SI/SM Project lifecycle;
5 The detailed SI/SM Project security activities and/or tasks, and their associated milestones and deliverables;
6 The design and/or engineering change possibilities within a Secure SI/SM Project lifecycle and those should be via a Management of Change (MOC) procedure to carry out appropriative SI/SM Project security impact and/or risk assessments for them; and
7 The activities required for a Secure SI/SM Project security implementation and verification and validation processes.

2.2 適用性和有效性 Applicability and Validity

2.2.1 適用性 Applicability

The document is applicable to a Secure SI/SM Project whole lifecycle. If there are additional applicable regulations, standards, or code and practices, or any security requirement specified by the System or IACS Automation Solution Users (i.e., the

Product Users), the Asset Owner, or the Customer or Client, the ICP's Project team should moderately consider, apply them, and make necessary engineering justifications.

2.2.2 有效性 Validity

This document is valid throughout the entire SI/SM Project lifecycle as well as the Secure SI/SM Project after Implementation and Verification and Validation (R3) stage, such as Operation and Support/Maintenance (R4) and Decommissioning/Disposal (R5) (i.e, EOS/EOL) stages, if applicable, while performing the security management activities during the Secure SI/SM Project lifecycle. The ICP's Project team shall have a management system or program to support SI/SM Project security activities based on this document in relation to the Systems or IACS Automation Solutions. All documentation related to a System or IACS Automation Solution security shall comply with the ICP's company QMS, SI/SM Project quality assurance (QA) and/or security assurance processes to delivery for review.

This document should be reviewed and revised if necessary, such as

1 Applicable regulations, standards, or code and practices changes or revisions;
2 After a major security incident;
3 The ICP's company security policies changes or revisions;
4 Any ICP's company-designated periodic review; and
5 Other designated by task-based project review.

3.0 Responsibility 責任

The P/SSO will be responsible for the promotion of the security management framework of Secure SI/SM Projects and support the security operation of secure Systems' or IACS Automation Solutions' processes.

4.0 Definitions 名詞定義

Ac	Acceptable
AD	Advanced Mitigation Strategies
ALARP	AS Low As Reasonably Practicable
AN	Analyst
AP	Attack Potential
Ar	Acceptable with a technical review
BCR	Benefit-to-Cost Ratio
BPCS	Basic Process Control System
BU	Business Unit
CBA	Cost-Benefit Analysis
CPNI	Centre for the Protection of National Infrastructure
CRRF	Cyber Risk Reduction Factor

CSA	Cybersecurity Assessor
CSA SG	Cyber Security Agency of Singapore
CSRS/CRS	Cybersecurity Requirements Specification
CSMS/CMS	Cyber Security Management System
CUS	External Party (Product Users, the Asset Owner, etc.)
DES	Designer
DESH	Designer for HW
DESS	Designer for SW
DEV	Developer
DM	Defect Management
DP	Damage Potential
DRAR	Detailed Risk Assessment Requirements
ENISA	European Union Agency for Cybersecurity
EOL	End-of-Life
EOS	End-of-Service or End-of-Sale
ES	Equipment/Device Security
EUC	Equipment Under Control
EUCC	EU Cybersecurity Certification
FAT	Factory Acceptance Test
FR	Foundational Requirement
HLCRA	High-Level Cybersecurity Risk Assessment
HW	Hardware
IAC	Identification and Authentication Control
IACS	Industrial Automation and Control System
ICSA	Independent Cybersecurity Assessment / Assessor
ID	Identity or Identifier
IEC	International Electrotechnical Commission
IEEE	Institute of Electrical and Electronics Engineers
IMP	Implementor
INT	Integrator
ISO	International Organization for Standardization
IT	Information Technology
ML	Maturity Level
MOC	Management of Change
MoM	Minutes of Meeting

NIST	National Institute of Standards and Technology
NPV	Net Present Value
NS	Network Security
NTIA	National Telecommunications and Information Administration
O&M	Operation and Maintenance
OECD	Organization for Economic Co-operation and Development
OT	Operational Technology
PBS	Product Breakdown Structure
PCM	Project Configuration Manager
PDS	Product Security
PDSC	Product Security Committee
PJSC	Project Security Committee
PHA	Preliminary Hazard Analysis
PJS	Project Security
PJSC	Project Security Committee
PM	Project Manager
PQM	Project Quality Manager
PR	Programmer for Software
P/SSO	Project/System Security Office
QA	Quality Assurance
QMS	Quality Management System
RA	Resource Availability
RAGAGEP	Recognized and Generally Accepted Good Engineering Practices
RDF	Resource Description Framework
RQM	Requirements Manager
SA	System Administration
SAC	Security Analysis Center
SAT	Site Acceptance Test
SBOM	Software Bill of Materials
SCA	Static Code Analysis
SI	Integration Service
SIF	Safety Instrumented Function
SIS	Safety Instrumented System
SIT	Site Integration Test
SL	Security Level

SLA	Service Level Agreement
SL-A	Achieved Security Level
SL-C	Capabilities Security Level
SL-T	Target Security Level
SM	Maintenance Service / Security Management
STC	Security Test Center
SuC	System under Consideration
SUM	Security Update Management
SVV	Security Verification and Validation
SVVP	Security Verification and Validation Testing Plan
SW	Software
SYS	System Engineer
TAICS	Taiwan Association of Information and Communication Standards
TL	Technical Leader for SW
TR	Technical Report
TRA	Threat and Risk Assessment
TST	Tester
TTPs	Tactics, Techniques, and Procedures
TVRA	Threat, Vulnerability, and Risk Analysis
UC	Use Control
Ud	Undesirable
UK	United Kingdom
Un	Unacceptable
US	United States
V&V	Verification and Validation
VAL	Validator
VER	Verifier
ZCR	Zone and Conduit Requirements

5.0 Instructions 作業說明

5.1 安全系統整合/維護服務專案概述 Secure SI/SM Project Overview

5.1.1 專案概述 Project Overview

The generally overall context to which the Secure SI/SM Project should be presented in an SI/SM Project Security Management Plan. The corresponding project descriptions which including purposes, objectives, and scope, contracture requirements if applicable, delivery strategy, master planning, and relevant stakeholders should be shown.

If this is a security issue that occurs in the Operation and Support/Maintenance (R4) and Decommissioning/Disposal (R5) stages of an SuC, the requirements specified in the ICP's SI, SM Project and System Security Management Guideline and in the OT Security Requirements for dummy project shall be followed.

5.1.2 系統或 IACS 自動化解決方案概述 System or IACS Automation Solution Overview

The following component security information and description of a System or IACS Automation Solution shall be prepared before its hand-over for operation or before its security patch/MOC for maintenance:

1 Component description;
2 Component identification;
3 Component label;
4 Version;
5 Identification during O&M, installation, configuration, deployment, and updates if applicable;
6 Proof of component integrity, primarily software;
7 Component category according to IEC 62443-4-2: software application, embedded component, host component, or network component;
8 Excluded parts of the component;
9 Component functionalities which are not considered due to deactivated by default and/or only activated for special cases and not the focal point;
10 Declaration of security requirements by stating a SL or by listing individual requirements, including possible requirement enhancements; and
11 Specification of the assumed attacker type (resistance level) by stating a SL or by describing the attacker (based on the definition given in the IEC 62443 series).

And, the intended use of the SuC shall be prepared and listed as follows:

1 Intended use;
2 Use cases;
3 Threat model;
4 Operational environment (mandatory and optional);
5 Security functionality;

6 Implementation mechanisms for security properties; and
7 Information on whether PKI techniques are supported if appropriate.

5.2 安全政策與管理理念 Security Policy and Management Philosophy

5.2.1 安全政策 Security Policy

The System or IACS Automation Solution Security Policy Statement describes the ICP's Project team commitment to the consideration of SuC security as a factor of paramount importance in the Secure SI/SM Project lifecycle stages and its whole security lifecycle. During the Secure SI/SM Project stages, as a means of guiding the management of SuC security activities, the ICP's SI/SM Project team will adopt and adapt, where necessary, the System or IACS Automation Solution security-related regulatory, standards, and code of practices required by the Secure SI/SM Project. Consideration of security as well as that for the (functional) safety of the System or IACS Automation Solution, if applicable, in the design processes will be given the highest priority by the ICP's Project team.

It is the ICP's and its subcontractors/vendors/suppliers' duty if applicable to:

1 Comply with the security policy stated in the reference document of this document – the SI/SM Project and System Security Management Guideline;
2 Comply with the requirements specified in this document;
3 Comply with the specific System or IACS Automation Solution security requirements contained within the Secure SI/SM Project;
4 Participate in specific System or IACS Automation Solution security studies;
5 Highlight any threat identified during the course of their activities; and
6 Support the System or IACS Automation Solution security analysis and verify the performance of targets.

The Security Policy Statement of a Secure SI/SM Project and System or IACS Automation Solution should be stated in an SI/SM Project Security Management Plan. The project official management and Project Manager of the ICP's Project team should promise to give priority to and fully support the proposed security policy.

5.2.2 安全管理理念 Security Management Philosophy

The System and IACS Automation Solution security and safety (where applicable) management philosophy describes management's approach for ensuring the effectiveness of the SuC security and safety program and the achievement of SuC objectives.

The imperative philosophy is as follows:

1 Security and safety considerations will always take priority over other project considerations such as timescales, cost or operational factors within the context of the AS Low As Reasonably Practicable (ALARP) principle which will be customized to reflect local practices such as mitigation through rules and procedures if a design out is not practically feasible;

2 A unified approach to System or IACS Automation Solution security and safety management that cuts across the ICP's boundaries and, where appropriate, its subcontractors/vendors/suppliers;

3 All system security and safety activities will be planned based on an analysis of activities needed to meet the System and IACS Automation Solution security and safety requirements;

4 Pro-active approach to solving System and IACS Automation Solution security and safety issues in the definition of design control measures or operational and maintenance controls;

5 Involvement of key engineering/design and Project staff in the System and IACS Automation Solution security and safety decision-making process and System and IACS Automation Solution security and safety review processes;

6 Close liaison amongst the security and safety organization and the engineering/design teams, implementation/integration staffs and test staffs to ensure the early identification of potential System and IACS Automation Solution security and safety problems or issues;

7 Active involvement of the engineering/design teams in the preparation of System and IACS Automation Solution security and safety studies including attendance at hazards/threats identification sessions and development of any design or operational control measures to reduce risks to a tolerable level;

8 Ownership and responsibility for resolution of hazards/threats rest with specific members within the nominated project team members;

9 Standardized System and IACS Automation Solution security and safety methods will be used across the project to facilitate the communication of System and IACS Automation Solution security and safety issues, the integration of analyses and the identification and resolution of interface-related issues;

10 Conflicts between security/safety-focused tasks, which aim at the avoidance of accidents and incidents, and other project progress tasks, where cost and capacity concerns are likely to be the prime driver, will be clearly identified and subject to trade-off studies, design or operational reviews to identify and implement optimized solutions within the context of the ALARP principle;

11 Conflicts between System and IACS Automation Solution security/safety and other project (and/or System and IACS Automation Solution) requirements will be clearly identified and subject to trade-off studies, design, or operational reviews to identify and implement optimized solutions; and

12 There will be regular and frequent monitoring of the System and IACS Automation Solution security and safety program progress and technical performance for the early detection of issues and deficiencies and prompt implementation of corrective action.

13 Request and training the team members and subcontractors/consultants to follow the requirement from the Employer:

(1). The Employer's security requirements, policies, and procedures

(2). The Employer's Management of Change (MOC) and Permit to Work (PtW) processes for changes involving devices, workstations, and servers and connections between them.

(3). The protection of the confidentiality of the Employer's data. All the policies, procedures required to protect the confidentiality of the asset owner's data also shall be listed. The document and data should follow ISMS-P-03 Information Asset Management Procedure.

5.3 安全保證組織 Security Assurance Organization

5.3.1 專案安全保證組織 Project Security Assurance Organization

A typical organizational structure from System or IACS Automation Solution level perspectives and as a reference is shown in Figure1. when this System or IACS Automation Solution is also applicable functional safety requirements.

Notice that the System or IACS Automation Solution SI/SM Project engineering team, i.e. the SYS/DES/DEV/TL/AN/PR/IMP team, may be adjusted to plan and develop lower-level organizations in accordance with the ICP's existing procedures or practices; the project quality management team, of which including PCM and RQM, they may also make appropriate adjustment planning based on the ICP's existing project quality management practices; while the INT/TST and VER/VAL teams need to further follow the requirements stated in Section 5.7.2.2 of this guideline and those described in the SI/SM Project and System Security Management Guideline to establish related task groups and/or teams.

The following roles of a typical project security assurance organization must be planned by following the description stated in Section 5.3.2 of this guideline. Their related responsibilities and competency requirements should be arranged and specified in accordance with the reference provisions described in Section 5.3.3 of this guideline or referred to a specified source. The prescribed roles, responsibilities, and competency requirements stated in the SI/SM Project and System Security Management Guideline and cited by this document, such as TST, VER, VAL, and PJSC, should also be complied with.

PM – Project Manager

PQM – Project Quality Manager

PJSC – Project Security Committee – Led by PJS Leader and assigned by P/SSO

PJS – Project Security Leader that representative of PJSC and assigned by P/SSO

PCM – Project Configuration Manager (Can be assigned or delegated by PQM, if necessary)

RQM – Requirements Manager (Can be assigned or delegated by PQM, if necessary)

CUS – External Party (System or IACS Automation Solution Users (i.e., Product Users), the Asset Owner, etc.)

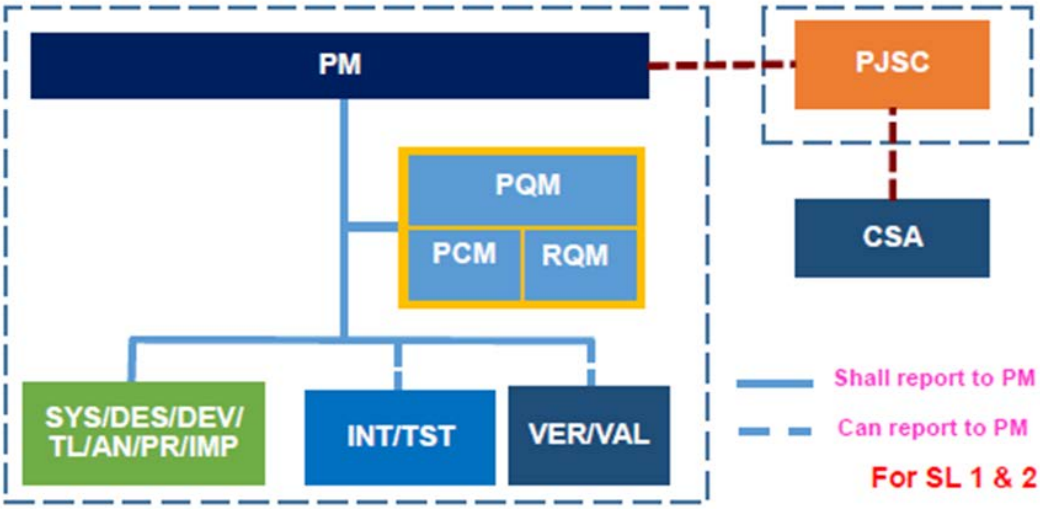
SYS – System Engineer

DES – Designer (Can be designated by SYS or concurrently, if necessary)

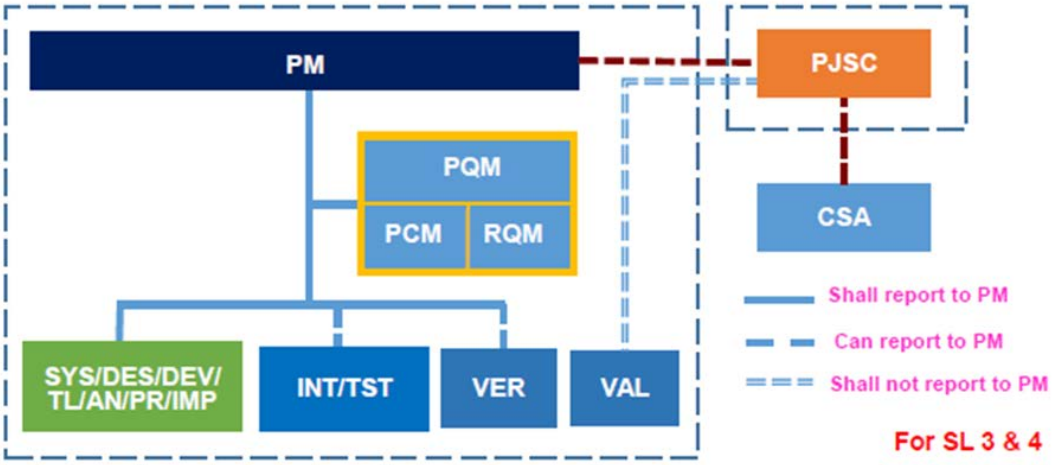
DEV – Developer, if necessary

DESH – Designer for HW, if necessary

DESS – Designer for SW, if necessary
TL – Technical Leader for SW, if necessary
AN – Analyst for SW, if necessary
PR – Programmer for SW, if necessary
IMP – Implementor, if applicable
INT – Integrator, if applicable
TST – Tester
VER – Verifier – SAC and/or STC experts can be assigned by PJSC of P/SSO or PDSC of P/SSO to assist in execution
VAL – Validator – SAC and/or STC experts can be assigned by PJSC of P/SSO or PDSC of P/SSO to assist in execution
CSA – Cybersecurity Assessor – Can be assisted by PJSC of P/SSO, PDSC of P/SSO or appointed by qualified external experts if required



(a) For SL 1 & 2



(b) For SL 3 & 4

Figure1. Typical Project Security Assurance Organization.

As that illustrated in Figure1., the organizational independence requirements are basically planned as follows:

1 SYS/DES/DEV/TL/AN/PR/IMP should be separated to INT/TST and to Security Verification and Validation (SVV) (VER and VAL).
2 VER and VAL will be suggested to be independent for SL 3 & 4.
3 CSA should be planned if applicable and should be independent of the whole project team.
4 VER and VAL:
   (1) Independent person for SL 1 & 2.
   (2) Independent department for SL 3 & 4.
5 CSA:
   (1) Independent department for SL 1 & 2.
   (2) Independent organization for SL 3 & 4.

If the System or IACS Automation Solution does not require to comply with the functional safety requirements related to the IEC 61508 standards family and its specific applications' standards, the following required level of independence of TST/VER/VAL from SYS/DES/DEV/TL/AN/PR/IMP/INT shall comply as a minimum:

1 Penetration testing – Independent department or organization;
2 Security requirements testing – Independent department;
3 Threat mitigation testing – Independent department (if required and necessary);
4 Abuse case testing – Independent person (if required and necessary);
5 Attack surface analysis – Independent person (if required and necessary);
6 Known vulnerability scanning – Independent person (if required and necessary);
7 Static code analysis (SCA) – None (if required and necessary); and
8 SW composition analysis – None (if required and necessary).

In addition, based on different national or regulatory requirements, different Asset Owners' or Customer's/Clients' requirements, it may be necessary to implement Vulnerability Inspection and Testing of Systems or IACS Automation Solutions and to management Open Chain and SBOM security issues, the Secure SI/SM Project Manager should arrange and assign appropriate TST/VER/VAL team members to perform relevant activities or tasks, if applicable.

5.3.2 角色與責任 Roles and Responsibility

Before assigning the personnel of the roles and responsibility of security activities and tasks, PM should refer the SI/SM Project and System Security Management Guideline chapter 6.2 Organization, Roles, and Responsibilities. For the key competencies requirement for roles can be referred to Annexes Table B.1. PM should choose people with appropriate expertise (It may be recorded in the QP-02-01: 基本資料表/個人訓練履歷表) to assign. The roles and responsibility of security activities and tasks described in Section 5.5.2 and security assurance deliverables specified in Section 5.5.3 for a Secure SI/SM Project from system level perspectives shall be assigned and provided in a Secure IACS Automation Solutions

SI/SM Project Security Management Plan. It shall comply with the independence level of a security assurance organization specified in Section 5.3.1 to arrange human resources for each role and responsibility of a security assurance program. The proforma forms of Table 1 and Table 2 are suggested to use for human resources planning.

Table 1. Roles and Responsibility Assignment for Each Security Activity and/or Task on a Security Assurance Program of a Project. (Example)

Stage	Task ID	Task/Description	IMP	VER	VAL	Assessor
R0	SSA-PRO-001	Define Security Requirements for Tender	Implementor1	VER_assessor1	PM_person1	
R0	SSA-PRO-002	Evaluate Security Specification	Implementor1	VER_verifer1	PM_person1	VER_assessor1
R0	SSA-PRO-003	R0 Gate Review	Implementor1	VER_assessor1	PM_person1	
R1	SSA-PLN-001	Security planning & risk assessment	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	SSA-REQ-001	Systems security classification	Implementor2	VER_assessor1	PM_person1	
R1	SSA-REQ-002	Threat & Risk Assessment (Preliminary)	Implementor2	VER_assessor1	PM_person1	
R1	SSA-REQ-003	R1 Gate Review	Implementor2	VER_assessor1	PM_person1	
R2	SSA-DES-001	For each zone, design and document the technical and organizational cybersecurity policies, measures, or countermeasures	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	SSA-DES-002	Review Security Architecture	Implementor2	VER_assessor1	PM_person1	
R2	SSA-DES-003	Review Security Controls	Implementor1	VER_assessor1	PM_person1	
R2	SSA-DES-004	R2 Gate Review	Implementor2、Implementor3	VER_assessor1	PM_person1	
R3	SSA-ENG-001	Implement SuC cybersecurity measures or countermeasures and conduct cybersecurity testing	Implementor1	VER_verifer1	PM_person1	
R3	SSA-ENG-002	Perform Source Code Review, if applicable	Implementor3	VER_verifer1	PM_person1	
R3	SSA-ENG-003	Perform Application Security Testing	Implementor3	VER_verifer2	PM_person1	

Stage	Task ID	Task/Description	IMP	VER	VAL	Assessor
R3	SSA-ENG-004	Perform System Security Testing	Implementor3	VER_assessor1	PM_person1	
R3	SSA-ENG-005	Perform Penetration Testing	Implementor2	VER_assessor1	PM_person1	
R3	SSA-ENG-006	R3 Gate Review	Implementor3	VER_assessor1、VER_verifer2	PM_person1	
R4	SSA-O&M-001	Perform security review	Implementor3	VER_verifer1	PM_person1	
R4	SSA-O&M-002	Perform type/setting/configuration management	Implementor1	VER_verifer1	PM_person1	
R4	SSA-O&M-003	Perform MOC	Implementor1	VER_verifer1	PM_person1	
R4	SSA-O&M-004	Regular security testing and/or evaluation	Implementor3	VER_verifer1	PM_person1	
R4	SSA-O&M-005	SuC's cybersecurity incident response and recovery	Implementor2	VER_assessor1	PM_person1	
R4	SSA-O&M-006	Perform continuous monitoring	Implementor2	VER_assessor1	PM_person1	
R4	SSA-O&M-007	R4 Gate Review	Implementor2、Implementor3	VER_assessor1	PM_person1	
R5	SSA-EOS-001	Preserve Information	Implementor1	VER_verifer1	PM_person1	
R5	SSA-EOS-002	Sanitize Media	Implementor1	VER_verifer1	PM_person1	
R5	SSA-EOS-003	Dispose Hardware and/or Software	Implementor1	VER_verifer1	PM_person1	
R5	SSA-EOS-004	R5 Gate Review	Implementor1	VER_assessor1	PM_person1	

Table 2. Roles and Responsibility Assignment for Security Assurance Deliverables. (Example)

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor
R0	0.01	Tender Security Requirements	Implementor1	VER_assessor1	PM_person1	
R0	0.02	Security Compliance Report	Implementor1	VER_verifer1	PM_person1	VER_assessor1

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor
R0	0.03	Security Requirements	Implementor1	VER_verifer1	PM_person1	VER_assessor1
R1	1.01	Security Management Plan	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	1.02	Vendor (and/or Subcontractors) Security Management Plan	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	1.03	Security Policies and Procedures - Preliminary	Implementor1	VER_assessor1、VER_verifer1	PM_person1	
R1	1.04	Preliminary (or High-level) Security Requirements	Implementor2	VER_assessor1	PM_person1	
R1	1.05	Simple Network Diagram	Implementor2	VER_assessor1	PM_person1	
R1	1.06	Asset Inventory List - Preliminary	Implementor2	VER_assessor1	PM_person1	
R1	1.07	Threat and Risk Assessment Report - Preliminary	Implementor2	VER_assessor1	PM_person1	
R2	2.01	Asset Inventory List	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	2.02	Network and Data Flow Diagram	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	2.03	Detailed Threat and Risk Assessment Report	Implementor2	VER_assessor1	PM_person1	Assessor2
R2	2.04	Security Risk Mitigation Plan and Requirement Specifications	Implementor2	VER_assessor1	PM_person1	Assessor2
R3	3.01	IACS Automation Solutions/Asset Hardening Recommended Practices	Implementor1	VER_verifer1	PM_person1	
R3	3.02	Security Policies and Procedures (Security Functional Description Specification)	Implementor1	VER_verifer1	PM_person1	
R3	3.03	Security Solution Integration Plan for Security Policy and Procedure Design Best Practices	Implementor1	VER_verifer1	PM_person1	
R3	3.04	Security Inspection and Test Protocol	Implementor1	VER_verifer1	PM_person1	
R3	3.05	Security Verification and Validation Testing	Implementor3	VER_verifer2	PM_person1	

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor
		Plan (SVVP)				
R3	3.06	Incident response and recovery plan	Implementor3	VER_assessor1	PM_person1	
R3	3.07	FAT Test Cases – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.08	FAT Report – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.09	Source Codes Review Report	Implementor3	VER_verifer1	PM_person1	
R3	3.10	SBOM	Implementor3	VER_verifer1	PM_person1	
R3	3.11	Application and Vulnerability Assessment Testing Report	Implementor3	VER_verifer2	PM_person1	
R3	3.12	SAT Test Cases – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.13	SAT Report – Related to security	Implementor3	VER_verifer2	PM_person1	
R3	3.15	SIT Report – Related to security	Implementor2	VER_assessor1	PM_person1	
R3	3.17	Penetration Testing Report – Related to security	Implementor2	VER_assessor1	PM_person1	
R3	3.18	SLA Protocol	Implementor3	VER_verifer2	PM_person1	
R3	3.19	Security Case – R3 stage	Implementor3	VER_assessor1、VER_verifer2	PM_person1	
R3	3.20	ICSA Report – R3 stage	Implementor3	VER_assessor1、VER_verifer2	PM_person1	

5.3.3 能力要求 Competency Requirements

The roles of the tasks planned for the Secure IACS Automation Solutions SI/SM Project should not only be subject to appropriate personnel competency requirements but should also be subject to organizational independence level requirements.

Security assurance key personnel in the organization, such as PM, PQM/PCM/RQM, PJSC/CSA, SYS, TL/AN (if applicable), TST, SVV, etc., their brief qualifications and/or curriculum vitae should be stated in an SI/SM Project Security Management Plan or displayed in the Competence Management System established by the ICP's human resources management organization. Their detailed information can be attached to the Annex of an SI/SM Project Security Management Plan or be referred to the ICP’s human resources system as required.

For all the phases or stages of the secure IACS Automation Solutions SI/SM Project lifecycle, the key competences required for each role described in Section 5.3.2 in the execution of the Project should be compliant with the indications given by the ICP and with the essential training and knowledge about security to understand IEC 62443.

For the key security roles and responsibilities, such as PM, VER, VAL, TST, and

CSA or Independent Security Assessor, their designed responsibilities and key competencies requirements are given in Table 5 as a reference.

The Responsibilities and Key Competencies are listed in Table 5, If there are deficiencies in personal expertise, they should be included in the QP-02-01 基本資料表/個人訓練履歷表(Personal Training Resume) and tracked and managed according to QP-02 人事及教育訓練管理程序(Personnel and Training Management Procedure). (Refer to the SI/SM Project and System Security Management Guideline chapter 6.3 Personnel and Expertise) .

5.3.3.1 安全背景調查 Security-Related Background Checks

During the execution of task [SSA-PLN-001] Security planning & risk assessment and development of output [1.02] Vendor (and/or Subcontractors) Security Management Plan, the security-related background checks for the team members and subcontractors/consultants should be performed, where feasible, and to the extent allowed by applicable law.

5.3.3.2 知識與技能需求與評估 Knowledge and skills requirements and evaluation

Role	Personnel Name/ Suncontractor Name	Qualifications/ Experience required	Training that should be received	To be trained/ qualified
Implementor 1	XXX	More than 2 years of experience in software development	ISA IEC 62443 Cybersecurity Fundamentals Specialist	IEC 62443 aware training
Implementor 2	XXX	More than 2 years of experience in system integration	ISA IEC 62443 Cybersecurity Fundamentals Specialist	IEC 62443 aware training
Implementor 3	XXX	More than 2 years of experience in system development	ISA IEC 62443 Cybersecurity Design Specialist	IEC 62443 aware training
VER_assessor 1	XXX	More than 5 years of experience in software development	ISAIEC 62443 Cybersecurity Risk Assessment Specialist	IEC 62443 aware training
VER_assessor 2	XXX	More than 5 years of experience in system integration	ISA IEC 62443 Cybersecurity Design Specialist	Already met
VER_verifer1	XXX	More than 2 years of system testing	ISA IEC 62443 Cybersecurity Maintenance Specialist	Already met
VER_verifer2	XXX	More than 2 years of quality ensurence		Already met
PM_person1	XXX	More than 10 years of experience in project management	ISAIEC 62443 Cybersecurity Expert	Already met

Note: All involved personnel need to sign in review column in cover page after agree the work assigning.

5.3.4 其他相關計畫的介面管理 Management of Interfaces with Other Relevant

Programs

The interfaces between the Secure IACS Automation Solutions SI/SM Project management program and other stakeholders as well as management activities related to the following programs should be described when applicable:

1 Assigns personnel and Interfaces with Employer/Asset Owner for the project management, the tasks including
   (1) To inform and get the approval of the PE/O of changes to new personnel (including ICP, subcontractor, and/or consultant personnel) who need to get access to the solution. It would be performed and reported in the regular meeting.
   (2) To inform and get the approval of the PE/O of changes to personnel (including ICP, subcontractor, and/or consultant personnel) who no longer need access to the solution. It would be performed and reported in the regular meeting.
2 Interfaces with the (ICP's and Project's) Quality Management Program;
3 Interfaces with the (ICP's and Project's) Risk Management Program if applicable;
4 Interfaces with the ICP's Information Security Management Program;
5 Interfaces with the Project's Safety Management Program if applicable;
6 Interfaces with the (ICP's or Project's) Supply Chain Management Programs;
7 Interfaces with the Secure SI/SM Project Engineering Program if applicable; and
8 Interfaces with the Secure SI/SM Project Maintenance Service Program.
9 Assigns Project Security Leader that representative of PJSC to manage/audit/V&V the security of project. It should refer the key competencies requirement for the role in Annexes Table B.1, and select the personnel with appropriate expertise (It may be recorded in the QP-02-01: 基本資料表/個人訓練履歷表) to assign. If there are deficiencies in personal expertise, they should be included in the QP-02-01 基本資料表/個人訓練履歷表(Personal Training Resume) and tracked and managed according to QP-02 人事及教育訓練管理程序 (Personnel and Training Management Procedure)

5.4 安全績效目標與要求 Security Performance Targets and Requirements

Unless the customer or client has specified applicable security goals, targets, objectives, and security requirements for the Secure IACS Automation Solution, or the Secure IACS Automation Solution is a low-risk application with adequacy and complete threat model and its security profile have been established, the security goals, targets, objectives, and security requirements shall be given in accordance with the requirements specified in the SI/SM Project Security Management Guideline.

5.4.1 風險分類矩陣 Risk Classification Matrix

A Risk Classification Matrix shall be assigned for a Secure IACS Automation

Solutions SI/SM Project if needed. The tolerability of risk for a System or IACS Automation Solution will be in accordance with the classifications and criteria tabulated in Figure .

風險矩陣 (Risk Matrix)		衝擊 (Impact)			
		輕微的 (Minor) (1)	中度的 (Moderate) (2)	重大的 (Major) (3)	關鍵的 (Critical) (4)
概率/可能性(Likelihood)	必然的(Certain) (5)	5	10	15	20
	容易的(Likely) (4)	4	8	12	16
	可能的(Possible) (3)	3	6	9	12
	不太可能的(Unlikely) (2)	2	4	6	8
	罕見的(Remote) (1)	1	2	3	4

Figure 2. Risk Category for a System or IACS Automation Solution.

Where the definition of Risk Categories is given in Figure .

風險等級 (Risk Level)	數值 (Value)	風險類別 (Risk Category)	分級識別碼 (Ranking ID)	描述 (Description)
低 (Low)	<3	可接受的 (Acceptable)	Ac	通常不需要進一步降低風險 Further risk reduction not normally necessary
中 (Medium)	3-5	經技術審查可接受 (Acceptable with technical review)	Ar	優先級低於Ud網絡威脅，但仍有可能根據ALARP實現降低風險 Lower priority than Ud cyber threats, but risk reduction still to be achieved in accordance with ALARP
高 (High)	6-9	不受歡迎的 (Undesirable)	Ud	必須根據ALARP原則高度重視降低風險 High priority must be given to risk reduction in accordance with the ALARP principle
關鍵 (Critical)	>9	不可接受的 (Unacceptable)	Un	必須實現降低風險 Risk reduction must be achieved

Figure 3. Definition of Risk Categories.

Notice that the ALARP principle is described in Section5.2.2 of this document. Detail information about the evaluation of the Impact and Likelihood categories of a security incident/accident can be further referred to Appendix A of this document.

5.4.2 安全目標 Security Targets

The Security Targets of a secure System or IACS Automation Solution shall be determined. It will be allocated and/or determined via a security risk assessment or

specified by the ICP's, the Systems or IACS Automation Solutions Users, or the Asset Owner.

As demonstrated in Figure and Figure , the Risk Category is divided into four categories: Acceptable (Ac), Acceptable with a technical review (Ar), Undesirable (Ud), and Unacceptable (Un).

In a security risk assessment, one will calculate or evaluate the Unmitigated Risk ($R_{unmitigated}$) by using the expression $R_{unmitigated}$ = I*L. Where "I" is the impact and "L" is the likelihood of a threat. The risk category of a secure System or IACS Automation Solution depicted in Figure and Figure could be adopted for evaluating the $R_{unmitigated}$ if properly or necessary. In this example, the scoring value of an Acceptable (Ac) risk target is less than three (3), and the Tolerable risk target can be assigned as the scoring value equal to three (3).

In case the $R_{unmitigated}$ risk level is higher than Ac, the necessary risk reduction methods, countermeasures, compensating countermeasure, or treatments should be arranged in accordance with the principle described in Section **錯誤! 找不到參照來源。**.

Notice that, if applicable, in accordance with the requirements specified in IEC 62443-3-2, the security targets shall be allocated and established for each security Zone or Conduit partitions of the Systems or IACS Automation Solutions.

The Security Targets should be expressed as a SL with a vector format defined in Annex 3.3, IEC 62443-3-3: SL-? ([FR,] domain) = {IAC UC SI DC RDF TRE RA}, where

SL-? = (Required) is the SL type. The possible formats are:

- SL-T = Target SL;
- SL-A = Achieved SL; and
- SL-C = Capabilities SL.

[FR,] = (Optional) Field indicating the FR that the SL value applies. The FRs are written out in abbreviated form instead of numerical form to aid in readability.

domain = (Required) The applicable domain that the SL applies. Domains can refer to zones, control systems, subsystems, or components.

5.4.3 最低合理可行原則 ALARP Principle

The ALARP Principle specified in the ICP's SI-SM Project Security Management Planning Guideline will be applied to the Project and/or the System.

5.4.4 安全要求 Security Requirements

As that stated in Section 4.7, IEC 62443-3-2 regarding the requirements for ZCR 6.1 - Cyber Security Requirements Specification (CSRS or CRS), the CSRS (or CRS) shall be created and documented based on the outcome of the detailed security risk assessment as well as general security requirements based upon ICP or site-specific policies, standards, and relevant regulations.

At a minimum, the CSRS (or CRS) shall include the following:

1 SuC description – see IEC 62443-3-2 Section 4.7.3: ZCR 6.2;
2 Zone and conduit drawings – see IEC 62443-3-2 Section 4.7.4: ZCR 6.3;
3 Zone and conduit characteristics – see IEC 62443-3-2 Section 4.7.5: ZCR 6.4;
4 Operating environment assumptions – see IEC 62443-3-2 Section 4.7.6: ZCR 6.5;
5 Threat environment – see IEC 62443-3-2 Section 4.7.7: ZCR 6.6;
6 Organizational security policies – see IEC 62443-3-2 Section 4.7.8: ZCR 6.7;
7 Tolerable risk – see IEC 62443-3-2 Section 4.7.9: ZCR 6.8; and
8 Regulatory requirements – see IEC 62443-3-2 Section 4.7.10: ZCR 6.9.

The rationale and supplemental guidance on each of the requirements can be referred to the reference document – the SI/SM Project and System Security Management Guideline and Appendix A of this document. A typical workflow diagram outlining the primary steps required to establish zones and conduits and assess security risk is also provided for reference.

For a Secure SI/SM Project, the relevant functional requirements, SLs, and/or SL-T shall be specified. Detail information about secure design and security requirements specification can be referred to the reference document – the SI/SM Project and System Security Management Guideline.

5.5 安全計畫和任務 Security Program and Activities

5.5.1 安全整合/維護服務專案生命週期 Secure SI/SM Project Lifecycle

The Secure SI/SM Project lifecycle stages from the System-level perspective could be as follows:

Lifecycle Stage	Substage	Process
Concept/Specification (R0/R1)	Tendering/Acquisition (R0)	Tender Security Requirements
		Tender Security Evaluation
		C0 Control Gate
	Project Initiation (R1)	Security Planning & Risk Assessment
		C1 Control Gate
Development/Design and Development (R2)	N/A	Detailed risk assessment
		Critical Security Design Review
		C2 Control Gate
Production/Implementation and Verification and Validation (R3)	N/A	Implementation of system security countermeasures
		Application Security Testing
		System Security Acceptance Testing
		Penetration Testing
		C3 Control Gate
Operation and Support/Maintenance (R4) – if applicable	N/A	Audit & Continuous Monitoring
		C4 Control Gate, if applicable
Decommissioning/Disposal (R5) – if applicable	N/A	Secure Disposal
		C5 Control Gate, if applicable

5.5.2 專案安全任務和/或活動 Project Security Tasks and/or Activities

According to the requirements specified in IEC 62443-2-2 ED1 and Section 5.5.1 of this document, the corresponding activities and/or tasks and related work outputs of a Secure SI/SM Project lifecycle stages shall be properly developed by the Project Manager in accordance with the following baseline plan:

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
Concept/ Specification - Tendering/Acquisition (R0)	Tender Security Requirements	SSA-PRO-001	Define Security Requirements for Tender / Develop Security Requirements for Tender	Security Requirements for Tender
	Tender Security Evaluation	SSA-PRO-002	Evaluate Security Specification / Assessing of security control specifications proposed by the Vendors	1. Security compliance report 2. Security Requirements deviation
	C0 Control Gate	SSA-PRO-003	R0 Gate Review / Review security compliance report & check the Security Requirements deviation	Approve Security Requirements
Concept/ Specification - Project Initiation (R1)	Security Planning & Risk Assessment	SSA-PLN-001	Security planning & risk assessment / 1. Identification and confirmation of key security roles in the system development project 2. Develop project development lifecycle management & configuration management plan 3. Identify the use of secure design, architecture, and coding standards 4. Security management plans of subcontractors/suppliers and consultants 5. Plan the security policies and procedures	1. Security Management Plan: ● Key security roles ● Common security expectations ● High-evel Security Schedule 2. Project lifecycle Security Management Plan, including Configuration Management Plan 3. Security Subcontractors/Suppliers Management Plan – Vendor Security Management Plan 4. Security Policies and Procedures Management Plan
		SSA-REQ-001	Systems security classification / Identify the security	1. Security classification of the System 2. High-level Security

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			classification of the System	Requirements
		SSA-REQ-002	Threat & Risk Assessment (Preliminary) / 1. Review of Functional Requirements Specification 2. Threats and vulnerabilities identification 3. Initial establishment of SuC's Preliminary Asset Inventory List and Simple Network Diagram 4. Risk identification, analysis, and evaluation (i.e., Risk assessment) 5. Recommendations of appropriate security controls	1. TRA Report 2. Risk Register 3. Preliminary Asset Inventory List 4. Simple Network Diagram
	C1 Control Gate	SSA-REQ-003	R1 Gate Review / Validate & Submit to Employer/Asset Owner: 1. The Project Security Management Plan, Configuration Management Plan, Security Policies and Procedures or Plan 2. TRA Report	1. Approve Security Management Plans, including security roles & responsibilities. 2. Approve Security Policies and Procedures/Plan 3. Approve TRA Report
Development/Design and Development (R2)	Detailed Risk Assessment, if applicable	SSA-DES-001	For each zone, design and document the technical and organizational cybersecurity policies, measures, or countermeasures / 1. Identify threats and document them 2. Identify and document vulnerabilities 3. Select a risk acceptance principle to establish	1. Asset Inventory List 2. Security Architecture: Network and Data Flow Diagram, if necessary 3. Security Controls: Security Risk Mitigation Plan and Requirement Specifications: ● Functional Requirements ● Security Countermeasures ● Cybersecurity

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			cybersecurity requirements: ● Apply Codes of Practice ● Countermeasures for citing and reference systems similarity ● Conduct Detailed Risk Assessment 4. Confirm the SL-T of the zones or conduits 5. Output Cybersecurity Requirements Specifications	Policy and Procedure requirements 4. Security Detailed Risk Assessment Report and/or Updated TRA, if necessary
	Critical Security Design Review	SSA-DES-002	Review Security Architecture / Review trust boundaries, information entry and exit points and data flows	1. Approve Security Architecture: Network and Data Flow Diagram 2. Update Security Detailed Risk Assessment Report and/or TRA, if necessary
		SSA-DES-003	Review Security Controls / Review of security controls proposed in the System design, assessment of its effectiveness and recommendations	1. Approve Security Controls 2. Update Security Detailed Risk Assessment Report and/or TRA, if necessary
	C2 Control Gate	SSA-DES-004	R2 Gate Review / Validate & submit to the Employer/Asset Owner: 1. Asset Inventory List 2. Security Architecture 3. Security Controls 4. Risk Assessment Report and/or TRA	1. Approve Security Design 2. Update Security Detailed Risk Assessment Report and/or TRA, if necessary
Production/Implementation and Verificati	Implementation of the System security countermea	SSA-ENG-001	Implement SuC cybersecurity measures or countermeasures and conduct cybersecurity testing /	1. IACS Automation Solutions/Asset Hardening (Hardening) Recommended

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
on and Validation (R3)	sures		1. Implementation of security countermeasures & cybersecurity Policy and Procedure requirements: ● Assurance security ● Network segmentation (architecture) security ● Account management security ● Configuration Management (CM) ● IACS Automation Solutions/Asset Hardening ● Wireless security, if applicable ● Safety Instrumented System (SIS) security, if applicable ● Remote access security, if applicable ● Event management security, if applicable ● Malware protection security, if applicable ● Patch management security, if applicable ● Backup/Restore security, if applicable 2. System development and maintenance 3. Development of Security Inspection and Test Protocol 4. Development of Security Solution	Practices 2. Security Policies and Procedures and/or Security Functional Description Specification: ● Account Management ● Vulnerability Management ● Backup and Restore Procedure ● Change and Patch Management Procedure ● Logging, Monitoring, and Reporting Procedure ● System Malware Protection Procedure 3. Security Inspection and Test Protocol 4. Security Solution Integration Plan for Security Policy and Procedure Design Best Practices 5. Incident response and recovery plan

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			Integration Plan for Security Policy and Procedure Design Best Practices 5. Development of incident response and recovery plan	
	Application Security Testing	SSA-ENG-002	Perform Source Code Review, if applicable / Source code review of applications from Functional Requirements	1. Review Source Codes 2. Action arising from review
		SSA-ENG-003	Perform Application Security Testing / 1. Perform Security Solution Integration 2. Application Security Testing for Functional Requirements & Security Countermeasures	Approve Application Testing Results
	System Security Acceptance Testing	SSA-ENG-004	Perform System Security Testing / 1. Security Equipment Under Control (FAT) 2. Security Inspection and Test Protocol (Inspection and checking the Hardening, Security Policy and Procedure implementation results, Security Solution Integration results, etc.) 3. Security SAT 4. Security SIT Test, if necessary	1. Approve Hardening Report 2. Approve Security Policies and Procedures and/or Security Functional Description Specification 3. Approve Security Inspection and Test Protocol 4. Approve Security Solution Integration Plan for Security Policy and Procedure Design Best Practices 5. Approve Incident Response and Recovery Plan 6. Approve Testing Result: ● Application and Vulnerability Assessment Testing Report, if applicable

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
				● Security FAT Report ● Security SAT Report ● Security SIT Report, if applicable 7. Action arising from tests
	Penetration Testing	SSA-ENG-005	Perform Penetration Testing / Perform Penetration Testing based on threats on SuC environment: manually or with the assistance of automated software tools	1. Penetration Testing Report 2. Actions arising from tests
	C3 Control Gate	SSA-ENG-006	R3 Gate Review / Validate and check: 1. Security controls defined by the agreed upon requirements are implemented in the System correctly. 2. Mitigation actions arising from source code review reports, security test reports and/or penetration test reports are addressed	Update TRA, if necessary
Operation and Support/ Maintenance (R4) – if applicable	Audit & Continuous Monitoring, if applicable	SSA-O&M-001	Perform security review / Security review: 1. The security controls in place continue to be effective over time, in light of system and environmental changes. 2. Assessing technology assets and technical security controls, security policies addressing issue such as acceptable use 3. Network rights should be reviewed to determine if administrative	1. Security Review Results 2. Actions arising from review

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
			security controls are effective	
		SSA-O&M-002	Perform type/setting/configuration management / 1. Review the type/setting/configuration management. 2. Assessment the changes to the system configuration of potential impact on the security of the System 3. Approve and changes in the operational environment	1. Update Asset Inventory List, if necessary 2. Update security documentation, if necessary
		SSA-O&M-003	Perform MOC / 1. Review the changes in the operational environment. 2. Approve and changes in the operational environment	1. Change Control decisions. 2. Update security documentation, Asset Inventory List, if necessary 3. Update TRA report, if necessary
		SSA-O&M-004	Regular security testing and/or evaluation / Scanning, conducting logs and continuously updating the security designs	Regular security testing and/or evaluation result
		SSA-O&M-005	SuC's cybersecurity incident response and recovery / Verify and exercise of shorten the impact time of security incidents	Cybersecurity incident response and recovery analysis and report, if applicable
		SSA-O&M-006	Perform continuous monitoring / Continuous Monitoring security reviews, self-assessments, vulnerability assessments and patch and end-point management	1. Security Reviews 2. Vulnerability Assessment results, if applicable 3. Actions arising from assessment, if applicable
	C4 Control Gate, if	SSA-O&M-007	R4 Gate Review / 1. Validation of security	Update TRA, if necessary

Stage/Sub-stage	Process	Activity/Task ID	Task/Activity Description	Deliverables
	applicable		reviews to ensure that built-in controls remain effective. 2. Validation of security assessment and reviews reports to ensure that Systems and environmental changes are addressed. 3. Regular review of TRA reports and risk register to ensure that risks remain valid and are continually addressed	
Decommissioning/ Disposal (R5 – if applicable	Secure Decommissioning/Disposal, if applicable	SSA-EOS-001	Preserve Information / Select the archival method that would facilitate information retrieval in the future	1. Disposal Plan 2. Index & Location of Information
		SSA-EOS-002	Sanitize Media / Using approved equipment, techniques, and procedures according to relevant policies and regulations to sanitize the System's digital media	Media Sanitization Records
		SSA-EOS-003	Dispose Hardware and/or Software / 1. The disposal of software should comply with license agreements. 2. The disposal of hardware.	1. Decommissioned or disposal records. 2. Update Asset Inventory list, if necessary
	C5 Control Gate, if applicable	SSA-EOS-004	R5 Gate Review / 1. Validation preserved information. 2. Validation of sanitization records 3. Validation of Asset Inventory list	

5.5.3 專案安全保證產出文件和時間表 Project Security Assurance Deliverables and

Schedule

The following planned list of a System or IACS Automation Solution security assurance documents to be produced during a Secure SI/SM Project lifecycle in its Concept/Specification (R0/R1), Development/Design and Development (R2), and Production/Implementation and Verification and Validation (R3) stages.

Item	**Description**	**Concept/Specification**			**Development/Design and Development**		**Production/Implementation and Verification and Validation**				**Note**
		Tendering/Acquisition		**Project Initiation**							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	**Detailed Risk Assessment**	**Critical Security Design Review**	**Implementation of the System security countermeasures**	**Application Security Testing**	**System Security Acceptance Testing**	**Penetration Testing**	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
0.01	Tender Security Requirements	P									If required
0.02	Security Compliance Report		P								If necessary
0.03	Security Requirements Deviation Analysis Reports (or Records)		P								If necessary
0.04	**C0 Control Gate – Formal Review Records**		P								
1.01	**Security Management Plan**			P							Should cover the overall security lifecycle of the Project
1.02	Vendor (and/or Subcontractors) Security Management Plan			P							If applicable
1.03	Security Policies and Procedures - Preliminary			P							If required Allows adoption of policies and procedures provided by the Asset Owner (Users) or Client
1.04	**Preliminary (or High-level) Security Requirements**			P							
1.05	**Simple Network Diagram**			P							Should include preliminary zones and conduits partition, as well as physical and logical network connection interface descriptions
1.06	**Asset Inventory List - Preliminary**			P							
1.07	Threat and Risk Assessment Report - Preliminary			P							Or HLCRA Report If necessary
1.08	**Security Risk Register - Preliminary**			P							Or Cyber Threats and Vulnerability

Item	Description	Concept/Specification			Development/Design and Development		Production/Implementation and Verification and Validation				Note
		Tendering/Acquisition		Project Initiation							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	Detailed Risk Assessment	Critical Security Design Review	Implementation of the System security countermeasures	Application Security Testing	System Security Acceptance Testing	Penetration Testing	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
											Log - Preliminary
1.09	Security Case – R1 stage			P							If required
1.10	ICSA Report – R1 stage			P							If required
1.11	**C1 Control Gate – Formal Review Records**			P							
2.01	**Asset Inventory List**				P	U*	U*	U*	U*		
2.02	**Network and Data Flow Diagram**				P	U*	U*	U*	U*		
2.03	Detailed Threat and Risk Assessment Report				P	U*	U*	U*	U*	U*	Or Detailed Cyber Risk Assessment Report, if necessary Detailed Security Risk Assessment Report and/or Updated TRA, if necessary
2.04	**Security Risk Mitigation Plan and Requirement Specifications**				P	U*	U*	U*	U*	U*	Or CSRS/CRS and Security Risk Mitigation Plan
2.05	Security Case – R2 stage					P					If required
2.06	ICSA Report – R2 stage					P					If required
2.07	**C2 Control Gate – Formal Review Records**					P					
3.01	IACS Automation Solutions/Asset Hardening Recommended Practices						P	U	U*		If required
3.02	**Security Policies and Procedures**						P	U	U*		Or Security Functional Description Specification, including: • Account Management • Vulnerability Management • Backup and Restore Procedure • Change and Patch Management Procedure

Item	Description	Concept/Specification			Development/Design and Development		Production/Implementation and Verification and Validation				Note
		Tendering/Acquisition		Project Initiation							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	Detailed Risk Assessment	Critical Security Design Review	Implementation of the System security countermeasures	Application Security Testing	System Security Acceptance Testing	Penetration Testing	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
											• Logging, Monitoring, and Reporting Procedure • System Malware Protection Procedure
3.03	Security Solution Integration Plan for Security Policy and Procedure Design Best Practices						P	U	U*		If required or necessary
3.04	**Security Inspection and Test Protocol**						P	U*	U*		Including FAT, SAT, and/or SIT, if applicable
3.05	Security Verification and Validation Testing Plan (SVVP)						P	U*	U*		If required or necessary
3.06	Incident response and recovery plan						P	U	U*		If applicable
3.07	FAT Test Cases – Related to security							P			If required or necessary
3.08	**FAT Report – Related to security**							P			
3.09	Source Codes Review Report							P	U*	U*	If applicable
3.10	SBOM							P	U*	U*	If required or necessary
3.11	Application and Vulnerability Assessment Testing Report								P		If applicable
3.12	SAT Test Cases – Related to security								P		If required or necessary
3.13	**SAT Report – Related to security**								P		
3.14	SIT Test Cases – Related to security								P		If required or necessary
3.15	SIT Report – Related to security								P		If required or necessary
3.16	Penetration Testing Cases – Related to security									P	If required
3.17	Penetration Testing Report – Related to security									P	If required
3.18	SLA Protocol									P	If required For supporting the security management during the stages in R4 and in R5
3.19	Security Case – R3 stage									P	If required
3.20	ICSA Report – R3 stage									P	If required
3.21	**C3 Control Gate – Formal Review**									P	

Item	Description	Concept/Specification			Development/Design and Development		Production/Implementation and Verification and Validation				Note
		Tendering/Acquisition		Project Initiation							
		Tender Security Requirements	Tender Security Evaluation	Security Planning & Risk Assessment	Detailed Risk Assessment	Critical Security Design Review	Implementation of the System security countermeasures	Application Security Testing	System Security Acceptance Testing	Penetration Testing	
		R0 (C0)		R1 (C1)	R2 (C2)		R3 (C3)				
	Records										
Note		P: Prepare; U: Update; U*: Update, if necessary									

5.5.4 服務水準協議/協定 Service Level Agreement (SLA) Protocol

The Client/Asset Owner or User of the System or IACS Automation Solution may sign a maintenance service contract with the SI/SM Service Provider regarding the Operation and Support/Maintenance (R4) and/or Decommissioning/Disposal (R5) stages. At this time, the Project Manager should complete the relevant SLA Protocol before the end of Production/Implementation and Verification and Validation (R3) stage, in addition to complying with the requirements of Section 5.5.2 of this document regarding the processes, tasks/activities, and document delivery of the R4 and/or R5 stages, its content should also comply with the requirements of the SI/SM Project and System Security Management Guideline.

5.6 安全保證方法 Secure Assurance Approach

5.6.1 一般原則 General Principles

Cybersecurity assurance programs can utilize the good practice developed in IEC 62443-3-3, IEC 62443-2-4, IEC 62443-2-1 ED1, and/or IEC 62443-2-1 ED2 for Systems and IACS Automation Solutions. These standards focus upon the management for integration and/or O&M of a secure System or IACS Automation Solution during its whole lifecycle.

The fundamental secure design principles include:

1 Secure by Design: A design principle where security measures are implemented early in the lifecycle of an IACS;

2 Reduce Attack Surface: A design principle where the physical and functional interfaces of an IACS that can be accessed and exposed to potential attack are minimized, making it more difficult for an attack to succeed:

(1) Access control (IAC and UC);

(2) Network segmentation;

(3) Least function; and

(4) Least privilege.

3 Defense-in-Depth: Being defined as the provision of multiple security protections, especially in layers, with the intent to delay or prevent an attack;

4 Essential Functions: To maintain health, safety, the environment, and availability of an Equipment Under Control (EUC). Essential functions include:

(1) The Safety-related Control Functions, or Safety Instrumented Function

(SIF);

(2) The critical control function; and

(3) The ability of the operator to view and manipulate an EUC.

The fundamental defense-in-depth philosophy of a System or IACS Automation Solution used in this document is based on the guidance specified the SI/SM Project and System Security Management Guideline.

In addition to referring to the above security principles, the Secure SI/SM Project team can explore suitable security principles based on best-practices of the specific application sector of a System or IACS Automation Solution. For example, CLC TS 50701 for railway applications, ISO/SAE 21434 and SAE J 3061 for road vehicles, and in general sectors, the United Kingdom (UK) Centre for the Protection of National Infrastructure (CPNI) good practice guide for process control and SCADA security, etc.

The security principles for a Secure System or IACS Automation Solution, if possible, should be stated in the Security Policies and Procedures, and the SLA Protocol, if required.

5.6.2 安全基線要求和控制措施 Baseline Security Requirements and Control Measures

The list of threats, vulnerabilities, and threat events related to a Secure System or IACS Automation Solution should be collected as far as possible in accordance with the requirements specified in the SI/SM Project and System Security Management Guideline, and their security requirements, security countermeasures, security profiles, baseline security requirements and control measures should be established and continuously updated during its Operation and Support/Maintenance (R4) and/or Decommissioning/Disposal (5) stages, if applicable and if required.

The ICP’s P/SSO shall be responsible for maintaining the novelty, completeness, and correctness of the aforementioned threat models. The Secure SI/SM Project team shall work closely with the PJSC led by a PJS Leader (or PDSC led by a PDS Leader) who responsible for and related to the System and Automation Solution security assurance to obtain the necessary security information and technology support.

Baseline Security Requirements and Control Measures are important input information for the specified security requirements and preliminary security risk assessment of a System or IACS Automation Solution in the early stages of its SI/SM Project execution.

5.6.3 安全保證流程 Security Assurance Processes

A typical Secure System or IACS Automation Solution SI/SM Project Security Assurance Processes should include:

1 Define the scope of the Security Assurance Program;

2 Plan the tasks and activities of the Security Assurance Program;

3 Establish a plan for Security Assurance Management;

4 Perform necessary cyber threats identification, vulnerability analysis,

cybersecurity risk assessment;

5 Determine the CSRS or CRS;

6 Perform Secure by Design on the System or IACS Automation Solution for its SI/SM Project execution (including Concept/Specification (R0/R1), Development/Design and Development (R2), Production/Implementation and Verification and Validation (R3) stages) tasks and activities in accordance with this document and the reference document – the SI/SM Project and System Security Management Guideline.

7 Plan the tasks and activities of the SVV in accordance with this document, which including:

(1) FAT Test Package:
- Weakness Detection and Vulnerability Testing: Weakness, Vulnerability Scanning identifies systems and system attributes, and attempts to detect known weaknesses and vulnerabilities;
- Threat Mitigation Testing: Verify the measures or countermeasures implemented to mitigate the threat and test the resilience of these implemented measures or countermeasures.

(2) SAT Test Package and Penetration testing:
- Repeat the FAT Test Package on SAT, if required;
- Penetration Testing: Penetration testing is a cybersecurity test used to determine how intrusion testers simulate real-world attacks to circumvent a system or cybersecurity function. Penetration testing is designed to demonstrate the resilience of IACS' SuC to identified threats and risks. It must be based on the detailed risk assessment results and the specific Tactics, Techniques, and Procedures (TTPs) attack possibilities and attack paths.

(3) SIT Test Package, if required or necessary:
- Penetration Testing;
- In some cases, it may be testing led by the Asset Owner or User.

8 Verify that the CSRS (or CRS) and SL-T of each Zone and each Conduit of a Secure System or IACS Automation Solution is valid and achieved. In some cases, it can be carried out with reference to the requirements of IEC 62443-2-2 ED1;

9 Validate the Secure System’s or IACS Automation Solution's cyber threats and security/cybersecurity risks have been effectively controlled to ALARP or Ac risk levels as expected;

10 Register and manage the Cyber Threats and Vulnerability Log (i.e., the Security Risk Register) for a Secure System or IACS Automation Solution and verify that all CSRS (or CRS) or security measures or countermeasures have been implemented correctly and effectively, and demonstration evidence is obtained, closing all cybersecurity requirements and cyber threats;

11 Establish an SLA Protocol, if required, for supporting the security management during the stages in Operation and Support/Maintenance (R4) and/or in

Decommissioning/Disposal (R5).

12 Perform management tasks and activities of the Security Management Program and management plan, including various types of reviews, checking, inspection, audits, verification and validation, assessment, and change management related to security.

A lifecycle management simplified V-model for a System level perspective is provided in Section 5.5of this document. The planned project configuration control stages for a Secure SI/SM Project lifecycle and its relevant tasks and/or activities are provided in Section 5.5.2 and Section 5.5.3.

The necessary security assurance processes, activities or tasks should be appropriately carried out based on this baseline plan.

5.6.4 安全研討 Security Studies

A Security Studies can be divided into:

1 Concept/Specification - Project Initiation (R1)
   (1) Discuss and develop security policies;
   (2) Identify existing security requirements for the acquisition process;
   (3) Define project security scope (including security objectives, constraints, and stakeholders);
   (4) Establish the Project security management plan;
   (5) Identify SuC;
   (6) Preliminary partition of Zones and Conduits of SuC;
   (7) Perform preliminary TRA (i.e., HLCRA);
   (8) Determine preliminary security requirements for SuC;
   (9) Perform CSAs led by PJS Leader/PJSC or by PDS Leader/PDSC or additionally assigned to Independent Security Assessor, if applicable or required;
   (10) Establish and prepare the Security Case – R1 stage, if required;
   (11) Perform ICSA and prepare the ICSA Report – R2 stage, if required; and
   (12) Hold Formal Review Meetings before the end of R1 stage.

2 Development/Design and Development (R2) - Detailed Risk Assessment, if applicable
   (1) Determine SuC and begin preliminary design;
   (2) Update SuC after preliminary design, if necessary;
   (3) Confirm Zones and Conduits;
   (4) Conduct detailed TRA, (i.e., Detailed Security Risk Assessment or DRAR), if applicable;
   (5) Apportionment of the System’s or IACS Automation Solution’s CSRS (or CRS), if applicable or required;
   (6) Prepare and review Preliminary Security Case, if required; and
   (7) Perform CSAs led by PJS Leader/PJSC (or PDS Leader/PDSC) or additionally assigned to Independent Security Assessor, if required;
   (8) Hold Formal Review Meetings before the end of R2 stage.

According to the reference document – the SI/SM Project and System Security Management Guideline and Appendix A of this document, the following tasks must be planned and executed:

(1) Planning the tasks and activities of the Concept/Specification - Project Initiation (R1) and Development/Design and Development (R2) - Detailed Risk Assessment, if applicable;
(2) Preparing the necessary procedures and test plans;
(3) Performing Security Risk Assessment (i.e., TRA);
(4) Completing the Security Risk Assessment Reports (i.e., TRA Report form HLCRA and/or DRAR, if applicable); and
(5) Determining the CSRS (or CRS).

The proforma forms of HLCRA and DRAR workbooks given in Table 3 and Table 4 can be used to conduct the HLCRA and detailed Security Risk Assessment (i.e, the Preliminary TRA and the Detailed TRA or DRAR) respectively.

In order to effectively maintain the threat model in a Secure System's or IACS Automation Solution's lifecycle, manage security performance, audit and monitor the effectiveness of safety/security preventive and/or mitigating safety/security control measures/ safety/security countermeasures/ safety/security compensating countermeasures, perform accident investigation of security incidents, and feedback and analysis from any security incident to effectively update the threat model, a visual threat modelling method, i.e. so-called Bowtie Method, can also be used for threat modelling, risk assessment, and security management.

3 Development/Design and Development (R2) - Critical Security Design Review

(1) Hold Security Review Meetings to discuss or review the SuC concept design, architecture design, the design of security measures, countermeasures, or an alternate means security risk reduction, if necessary;
(2) Perform CSAs led by PJS Leader/PJSC or by PDS Leader/PDSC or additionally assigned to Independent Security Assessor, if applicable or required;
(3) Establish and prepare the Security Case – R2 stage, if required;
(4) Perform ICSA and prepare the ICSA Report – R2 stage, if required;
(5) Hold Formal Review Meetings before the end of R2 stage, discuss or review:
    - the Asset Inventory List
    - the Security Architecture - Network and Data Flow Diagram
    - the Cyber Threats and Vulnerability Log (i.e., the Security Risk Register);
    - the CSRS (or CRS);
    - the Security Critical Elements, Requirements, and List, if appropriate; and

- the Security Case/ICSA Report – R2 stage, if required.

4 Production/Implementation and Verification and Validation (R3)

(1) Establish or Update the System's or IACS Automation Solution's asset hardening best practices, if required;

(2) Verify the Hardening Best Practices had already been implemented correctly and completely;

(3) Establish the Security Policies and Procedures and/or Security Functional Description Specification for the System or IACS Automation Solution, including:
- Account Management;
- Vulnerability Management;
- Backup and Restore Procedures;
- Change and Patch Management Procedures;
- Logging, Monitoring, and Reporting Procedures; and
- System Malware Protection Procedures.

(4) Establish and prepare the Security Solution Integration Plan for Security Policy and Procedure Design Best Practices, if required or necessary;

(5) Establish and prepare the Security Inspection and Test Protocol which including FAT, SAT, and/or SIT test package, if applicable;

(6) Establish and prepare the SVVP, if required or necessary;

(7) Establish and prepare the Incident Response and Recovery Plan/Procedures, if applicable;

(8) Establish and prepare the FAT, SAT, and/or SIT Test Cases which related to security, if required or necessary;

(9) Perform FAT, SAT, and/or SIT test packages (if required or necessary);

(10) Perform Source Codes Review, if applicable;

(11) Establish and prepare the Source Codes Review Report, if applicable

(12) Establish and prepare the SBOM, if required or necessary;

(13) Perform Application and Vulnerability Assessment Testing, if applicable

(14) Establish and prepare the Application and Vulnerability Assessment Testing Report, if applicable;

(15) Establish and prepare the Penetration Testing Cases, if required;

(16) Perform Penetration Testing, if required;

(17) Establish and prepare the FAT, SAT, and/or SIT Test Reports (if required or necessary);

(18) Establish and prepare the Penetration Testing Report, if required;

(19) Establish and prepare the SLA Protocol, if required (For supporting the security management during the stages in R4 and in R5);

(20) Perform CSAs led by PJS Leader/PJSC or by PDS Leader/PDSC or additionally assigned to Independent Security Assessor, if applicable or required;

(21) Establish and prepare the Security Case – R3 stage, if required;

(22) Perform ICSA and prepare the ICSA Report – R3 stage, if required; and

(23) Hold Formal Review Meetings before the end of R3 stage.

5 Project Closing (Before the end of R3 stage), if required

(1) Implement necessary countermeasures or improvement plans for the security issues discovered in the Stages of R1, R2, and/or R3, so that all discovered security issues can be completely solved and processed during the overall SI/SM Project lifecycle;

(2) Verify the Security Policies and Procedures and/or Security Functional Description Specification for the System or IACS Automation Solution, if required;

(3) Verify the SLA Protocol, if required; and

(4) Hold Formal Review Meetings to close R3 stage.

5.6.5 網宇威脅和漏洞日誌 Cyber Threats and Vulnerability Log

A Cyber Threats and Vulnerability Log should be implemented by the ICP and maintained by the designated PDS Leader/PDSC of P/SSO and used as a threats-tracking tool, at the system level and at the sub-system and/or HW/SW-level, if applicable of the System or IACS Automation Solutions (i.e., the SuC). It will allow recording, monitoring, and tracking of the implementation of security provisions to reduce risk throughout the Project and the SuC, up to the end of the SuC being hand overed to the Asset Owner or the SuC's Users.

The Cyber Threats and Vulnerability Log should be recorded by using the proforma form given in Table 8 when applicable. If any change or update was done in each Cyber Threats and Vulnerability Log submission to the PJSC or to the PDSC and/or its subcontractors/vendors/suppliers will highlight the change made.

A history log or change records shall be maintained to record each cyber threat update to facilitate traceability. The change records of the Cyber Threats and Vulnerability Log can be recorded by using the proforma form given in Table 9.

Notice that, in general, the Cyber Threats and Vulnerability Log and its change records will be recorded and updated via a supporting software tool progressively.

5.6.6 安全關鍵要素、要求和清單 Security Critical Elements, Requirements, and List

A Security Critical Elements, Requirements, and List should be built for each sub-system, equipment, component, and device of the SuC with the results of the various Security Studies and/or analyses performed all along with the Secure SI/SM Project progress. The Security Critical Elements, Requirements, and List gathers items which may, in the case of non-compliance with the identified security requirements, potential lead to a Critical or Major cyber threat incident. Security relevant critical elements or items can be a product, an interface, a task (e.g., operation, maintenance, etc.), or a function.

The Security Critical Elements, Requirements, and List should be established by using the proforma form given in Table 10 if applicable.

5.6.7 網宇威脅管理系統 Cyber Threats Management System

For the System, the cyber threats management requirements specified in the ICP's SI-SM Project Security Management Planning Guideline shall be applied to. It will be managed and supported via the ICP's relevant cyber threats management system appropriately.

5.7 安全保證管理 Security Assurance Management

5.7.1 品質管理 Quality Management

For the Project and the System, the requirements specified in the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline as well as the ICP's quality management systems' requirements shall be applied to.

5.7.2 安全管理 Security Management

5.7.2.1 符合性查證 Compliance Verification

For the Project and the System, the requirements specified in the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline shall be applied to.

5.7.2.2 安全查證與確證測試 Security Verification and Validation Testing

For the Project and the System, the requirements specified in the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline shall be applied to.

5.7.2.3 安全案例 Security Case

For the Project and the System, the requirements specified in the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline shall be applied to.

5.7.2.4 考量中的系統於維運和除役和/或廢棄階段的安全管理 The SuC Security Management during the Operation and Support/Maintenance and/or Decommissioning/Disposal Stages

For the Project and the System, the requirements specified in the ICP's SI-SM Project Security Management Planning Guideline and/or the ICP's SI, SM Project and System Security Management Guideline shall be applied to.

5.7.3 安全審查、稽核和評鑑 Security Reviews, Audits, and Assessment

5.7.3.1 概念/規範－專案啟動和開發/設計與開發階段 Concept/Specification - Project Initiation and the Development/Design and Development Stages

5.7.3.1.1安全審查會議 Security Review Meetings

The Security Review Meetings shall be convened to review the design relevant finding arisen from audits and design mitigation of high-risk threats (i.e., Ud/Un) at the end of the Concept/Specification (R1), the Development/Design and Development (R2), and the Production/Implementation and Verification and Validation (R3) stages where applicable. The Security Review Meetings should follow the process described in related international standards or engineering practices adopted in this document. Records of these Security Review Meetings shall be maintained by the ICP. Additionally, the Risk Register or specific Cyber Threats and Vulnerability Log shall keep track of any change to the log endorsed through the Security Review Meetings.

Any design changes arising after completion of the system security analyses, i.e., after specified the corresponding CSRS (or CRS) of the SuC, shall be evaluated for any potential security impacts and updated into the system security analyses accordingly. On the other hand, if a design change becomes necessary as a result of the system security analyses, it shall be submitted with sufficient technical information to the PJSC or PDSC for acceptance where applicable.

According to the pre-planned Configuration Control Stages of security program and activities in Section 5.5 of this document, the Project progress review performed by any check point and gate is formal and can be further combined with the Security Review Meetings.

The outputs of the Security Review Meetings shall be recorded in a Management of Change (MoM) and as part of the security assurance documents of the Project.

5.7.3.1.2安全保證稽核 Security Assurance Audits

1. Internal Security Assurance Audits

   Internal Security Assurance Audit will include:

   (1) QA team audits project security assurance team. This audit should be implemented twice a year normally or at least once within the Concept/Specification (R1) and the Development/Design and Development (R2) stages.

   (2) PJSC or PDS Leader (or QA team leader) audit subcontractors/vendors/suppliers about their security assurance activities where applicable. The preliminary audit program

should be provided and attached to this document. This program could be revised based on the progress and status of the Secure SI/SM Project.

2. For any resulting corrective action requests, proposed corrective and/or preventive action plan should be made. All proposed corrective and/or preventive action plans should be implemented and available for verification within the time period specified in the request. All identified remedial action requirements should be logged and followed throughout to ensure a satisfactory close-out. Security Assurance Audit Reports and corrective action requests should be maintained by the ICP and issued to its subcontractors/vendors/suppliers, where applicable, for management and close-out. The reports should contain a reference to the process and the organization being audited.
3. External Security Assurance Audits
   The Customer or Client may conduct Security Assurance Audit during the Secure SI/SM Project lifecycle. A notice period will be given by the Customer or Client prior to a proposed audit. During the audit, the Customer or Client will be given all necessary access, assistance, and facilities to enable verification that the security requirements and this document are being fully and properly implemented. The agreement shall be recorded with the Customer or Client following any such audits, as to any corrective and preventive actions required and the dates by which these actions will be completed.

5.7.3.2 生產/實施和查證與確證階段 Production/Implementation and Verification and Validation Stage

5.7.3.2.1安全保證稽核 Security Assurance Audits

Except that the QA team audit should be implemented once a year normally if required, all other audit requirements are basically the same as that will be planned for the Concept/Specification (R1) and the Development/Design and Development (R2) stages of the Secure SI/SM Project.

5.7.3.2.2安全檢驗 Security Inspections

On-site Security Inspections may be conducted by the Project security assurance team to identify any other potential threats against the applicable security requirements and the mitigation measures described in the Cyber

Threats and Vulnerability Log. Subject to the reasonable notification, the Secure SI/SM Project team should provide support for the security assurance team and, where appropriate, the relevant design team manager. An on-site security inspection may be conducted once for each stage after completing the Development/Design and Development (R2) stage. Updates to the security assurance deliverables shall be made accordingly as a result of these Security Inspections.

5.7.3.3 獨立安全評鑑 Independent Security Assessment

The purpose of Independent Security Assessment is to verify the documents of the Secure SI/SM Project and certify the design and design compliance of the works under the contract meet the Customer or Client contracture requirements or the SuC's Cyber Security Management System (CSMS/CMS) for security, functionality, and comply with relevant codes and standards.

The purpose of the Independent Security Assessment is also to provide an independent assessment of the achievement of the required security functions with SL requirements. The PJSC or PDSC can assign qualified personnel independently to serve as an Independent Security Assessor and perform CSA where appropriate. They shall work for the Concept/Specification (R1), the Development/Design and Development (R2), and the Production/Implementation and Verification and Validation (R3) stages, respectively. Any requirement (e.g. providing information, records, and/or reports related to the system security assurance activities, etc.) from Independent Security Assessment for review, assessment and/or audit shall be fully supported by the Secure SI/SM Project team.

5.8 使用表單 Proforma Table Use：

Table 3. Roles and Responsibility Assignment for Each Security Activity and/or Task on a Security Assurance Program of a Project.

Stage	Task ID	Task/Description	IMP	VER	VAL	Assessor

Table 4. Roles and Responsibility Assignment for Security Assurance Deliverables.

Stage	Doc ID	Task/Description	IMP	VER	VAL	Assessor

Table 5. Role Specifications for PM, VER, VAL, and CSA (or Independent Security Assessor).

Role: Project Manager (PM)
Responsibilities: 1. Take full responsibility of project management in relation to security assurance 2. Ensure that the Quality Management System (QMS) and independency of roles,

according to relevant parts of IEC 62443, are in place for the project and that progress is checked against the plans 3. Allocate sufficient number of competent resources in the project to carry out the essential tasks including security activities, bearing in mind the required independence of roles 4. Ensure that a suitable Validator (VAL) has been appointed for the project as defined in IEC 62443 5. Be responsible for the delivery and deployment of the System or IACS Automation Solution and ensure that security requirements from the stakeholders are also fulfilled and delivered 6. Allow sufficient time for the proper implementation and fulfilment of security tasks 7. Endorse partial and complete security deliverables from the development process 8. Ensure sufficient records and traceability is maintained in security-related decision making
Key Competencies: 1. Understand quality, competencies, organizational and management requirements of IEC 62443 2. Understand the requirements of the security process 3. Be able to weigh different options and understand the impact on security performance of a decision or selected options 4. Understand the requirements of the development process 5. Understand the requirements of other relevant parts of IEC 62443 standard

Role: Verifier (VER)
Responsibilities: 1. Develop a verification plan (which may include quality issues) stating what needs verification and what type of process (e.g., review, check, inspection, analysis, simulation, etc.) and test is required as evidence 2. Management the verification process (review, integration and testing) and ensure independence of activities as required 3. Check the adequacy (completeness, consistency, correctness, relevance and traceability) of the documented evidence from review, integration and testing with the specified verification objectives 4. Develop and maintain records on the verification activities 5. Develop a verification report stating the outcome of the verification activities and ensure that test activities are planned 6. Identify anomalies, classify these in risk (impact) terms, record and communicate these to relevant change management body for evaluation and decision 7. Manage testing for verification activities: ● Develop the test specification (objectives and cases) ● Execute tests according to the test specification and planning ● Ensure traceability of test objectives against the specified System or IACS Automation Solution security requirements ● Ensure traceability of test cases against the specified test objectives ● Ensure the planned tests are implemented and specified test cases carried out 8. Identify deviations from expected results and record them in test reports
Key Competencies: 1. Be competent in the domain where testing, integration and verification is carried out

2. Be competent in various test and verification approaches/methodologies and be able to identify the most suitable method or combination of methods in a given context
3. Be capable of deriving test cases from given specifications
4. Be Competent in understanding the design and functionality required at various intermediate levels
5. Be capable of deriving the types of integration test from a set of (integrated) security functions
6. Be capable of deriving the types of verification from given specifications
7. Have analytical thinking ability and good observation skills
8. Understand the relevant parts of IEC 62443

Role: Validator (VAL)

1. **Responsibilities**:
2. Establish an understanding of the System or IACS Automation Solution within the intended environment of application
3. Develop a validation plan and specify the essential tasks and activities for the validation and agree this plan with the Cybersecurity Assessor (CSA) or Independent Security Assessor, if present
4. Review the System or IACS Automation Solution requirements against the intended environment/use
5. Review the outcome against the System or IACS Automation Solution requirements to ensure all of these are fulfilled
6. Check the conformity of the process and the outcome against the requirements of this ISA/IEC 62443-3-2 standard including the assigned Security Level (SL)
7. Review the correctness, consistency and adequacy of the verification and testing
8. Check the correctness, consistency and adequacy of test cases and executed tests
9. Ensure all activities planned in the System or IACS Automation Solution validation plan are carried out
10. Review and classify deviations in terms of risk (impact), record and submit them to the body responsible for Change Management and decision making
11. Give a recommendation on the suitability of the outcome for intended use, and indicate any application constraints as appropriate
12. Capture deviation from the System or IACS Automation Solution validation plan
13. Carry out audits, inspections, or reviews on the overall project (as instantiations of the Secure SI/SM Project progress process) as appropriate in various stages of development
14. Review and analyze the validation reports of other generic applications, if being reused for the System under Consideration (SuC)
15. Check that developed solutions are traceable to the requirements
16. Ensure that related Cyber Threats and Vulnerability Log and remaining non-conformities are reviewed and all cyber threats and vulnerability closed out in an appropriate manner through elimination or risks control/transfer measures/countermeasures
17. Develop a validation report
18. Give agreement/disagreement for the release of the outcome

Key Competencies:

1. Be competent in the domain where validation is carried out
2. Be competent in various validation approaches/methodologies and be able to identify the most suitable method or combination of methods in a given context

3. Be capable of deriving the types of validation evidence required from given specifications bearing in mind the intended application
4. Be capable of combining different sources and types of evidence and synthesize an overall view about fitness for purpose or constraints and limitations of the application
5. Have analytical thinking ability and good observation skills
6. Understand the requirements of IEC 62443

Role: Tester (TST)

Responsibilities:

1. Plans, prepares, and executes tests of systems to evaluate results against specifications and requirements as well as analyze/report test results
2. Collect, verify, validate and analyze test data
3. Translate data and test results into evaluative conclusions
4. Give a recommendation on the suitability of the outcome for intended use, and indicate any application constraints as appropriate
5. Design a data analysis structure (i.e., the types of data a test must generate and how to analyze that data)
6. Conduct test events
7. Systems integration testing
8. Perform security testing
9. Develop a validation report

Key Competencies:

1. Be competent in the domain where validation is carried out
2. Security testing related certification
3. Have analytical thinking ability and good observation skills
4. Understand the requirements of IEC 62443
5. Cyber threats and vulnerabilities
6. Computer networking concepts and protocols, and network security methodologies
7. Developing operations-based testing scenarios
8. Writing code in a currently supported programming language (e.g., Java, C++, etc.).
9. Writing test plans and evaluating test plans for applicability and completeness
10. Designing and documenting overall program test and evaluation strategies
11. Identifying test and evaluation infrastructure (people, ranges, tools, instrumentation) requirements
12. Providing test & evaluation resource estimate
13. Managing test assets, test resources, and test personnel to ensure effective completion of test events
14. Preparing test & evaluation reports

Role: Cybersecurity Assessor or Independent Security Assessor

Responsibilities:

1. When tasked with Cybersecurity Assessor (CSA) or Independent Security Assessor, ensure to not become involved either directly or as authorized representative in the design, development, realization, implementation, manufacture/production, installation/integration/testing, marketing, operation or maintenance of the System or IACS Automation Solution under Cybersecurity Assessment or Independent Security Assessment (This does not exclude the possibility of exchange of technical information)

2. Establish understanding of the System or IACS Automation Solution within the intended environment of application
3. Develop an assessment plan and communicate this to the Project Security Committees (PJSC) and/or the System or IACS Automation Solution Users', or the Asset Owner's organization (contracting body of the assessor)
4. Evaluate the conformity of the process and the outcomes against the requirements of this IEC 62443 standard, including the Security Level (SL) assignment, capability verification, and SL-T achievement evaluation
5. Evaluate the competency of project staff and organization for the development
6. Evaluate the verification and validation activities and the supporting evidence
7. Evaluate the Quality Management Systems (QMS) adopted for the development
8. Evaluate the configuration and change management system and the evidence of its use and application
9. Identify and evaluate in terms of risk (impact) any deviations from the requirements in the assessment report
10. Evaluate the security audits have been carried out and documented in an appropriate way
11. Carry out inspections on the overall development process as appropriate at various stages of development
12. Give a professional view on the fitness of the developed outcome for its intended use, detailing any constraints, application conditions and observations for risk control as appropriate
13. Develop and maintain records and reports in accordance with the assessment plan

Key Competencies:

1. Be competent in the domain/technologies where independent assessment is carried out
2. Have acceptance/license from a recognized security authority, such as the Project Security Committees (PJSC) and/or the System or IACS Automation Solution Users', or the Asset Owner's organization (contracting body of the assessor)
3. Have/Strive to continually gain sufficient levels of experience in the security/cybersecurity principles, secure by design practices, and the application of the principles within the application domain
4. Be competent to check that a suitable method or combination of methods in a given context have been applied
5. Be competent in understanding the relevant security, human resource, technical and quality management processes in fulfilling the requirements of the IEC 62443
6. Be competent in independent assessment approaches/methodologies
7. Have analytical thinking ability and good observation skills
8. Be capable of combining different sources and types of evidence and synthesize an overall view about fitness for purpose or constraints and limitations on application
9. Have an understanding of the overall system including its application environment
10. Understand the requirement of IEC 62443

Table 6. The Proforma Form for Conducting the High-Level Cybersecurity Risk Assessment (HLCRA).

Threat-Vulnerability ID	Zone	Conduit	Asset ID	Description	Threats Description	Vulnerability Description	Attack Methods and Scenarios Description	Unwanted Incidents Description	Consequences	Proposed Security Measures/Control Measures/Countermeasures						DRAR Required?	Remarks
										Equipment/Device Security	Data Protection	System Administration	Application Security	Network Security	Advanced Mitigation Strategies		

Table 7. The Proforma Form for Conducting the Detailed Risk Assessment Requirements (DRAR).

Threat-Vulnerability ID	Zone	Conduit	Asset ID	Description	Threats Description	Vulnerability Description	Attack Methods and Scenarios	Unwanted Incidents Description	Consequences	Attack Potential (AP)						Damage Potential (DP)				Unmitigated Risk			Required SL-T		Proposed Security Measures/Control Measures/Countermeasures					Attack Potential (AP)						Damage Potential (DP)				Mitigated Risk			Achieved SL		Risk Tolerable or Acceptable?	Remarks
										Time to perform an attack	Expertise	Knowledge	Opportunity	Equipment	AP Value	Likelihood Level	Safety	Finance	Operational Functionality	DP Value	Impact Category	Risk Value	Risk Level	Risk Category	CRRF	SL-T	Equipment/Device Security	Data Protection	System Administration	Application Security	Network Security	Advanced Mitigation Strategies	Time to perform an attack	Expertise	Knowledge	Opportunity	Equipment	AP Value	Likelihood Level	Safety	Finance	Operational Functionality	DP Value	Impact Category	Risk Value	Risk Level	Risk Category	CRRF	SL-A		

Table 8. The Proforma Form for Recording the Cyber Threats and Vulnerability Log.

Threat-Vulnerability ID	Zone	Conduit	Asset ID	Description	Threats Description	Vulnerability Description	Attack Methods and Scenarios Description	Unwanted Incidents Description	Consequences	Attack Potential (AP)						Damage Potential (DP)				Unmitigated Risk			Required SL-T		Proposed Security Measures/Control Measures/Countermeasures					Confirmed Security Measures/Control Measures/Countermeasures		Resolution Status [Open, Open with Design Verification Completed (ODVC), Closed, Deleted]	Source	Threat-Vulnerability Status [Open, Open with Design Verification Completed (ODVC), Closed, Deleted]	Date Updated	Attack Potential (AP)						Damage Potential (DP)				Mitigated Risk			Achieved SL		Risk Tolerable or Acceptable?	Threat-Vulnerability Category Code	Verification and Validation Evidence Reference			Remarks
										Time to perform an attack	Expertise	Knowledge	Opportunity	Equipment	AP Value	Likelihood Level	Safety	Finance	Operational Functionality	DP Value	Impact Category	Risk Value	Risk Level	Risk Category	CRRF	SL-T	Equipment/Device Security	Data Protection	System Administration	Application Security	Network Security	Advanced Mitigation Strategies	1. ES: Equipment/Device Security 2. DP: Data Protection 3. SA: System Administration 4. AS: Application Security 5. NS: Network Security 6. AD: Advanced Mitigation Strategies	Functional Requirements ID [FR ID-Security Measures ID-xxx]				Date Updated	Time to perform an attack	Expertise	Knowledge	Opportunity	Equipment	AP Value	Likelihood Level	Safety	Finance	Operational Functionality	DP Value	Impact Category	Risk Value	Risk Level	Risk Category	CRRF	SL-A		Verification and Validation Stage	Verification and Validation Stage	Verification and Validation Stage		

Table 9. The Proforma Form for Recording the Change Records of the Cyber Threats and Vulnerability Log.

Threat-Vulnerability ID	Before Change		After Change	
	Remarks	Date Recorded	Remarks	Date Updated

Table 10. The Proforma Form for the Management of the Security Critical Elements, Requirements, and List.

Security Critical Elements, Requirements, and List ID	Security Critical Elements and/or Requirements Description	Relevant System/Sub-system/Equipment/Component/Device				Required SL-T		Consequences of Unwanted Incidents	Impact Category	Unmitigated Risk Category	Confirmed Security Measures/Control Measures/Countermeasures		Threat-Vulnerability ID	Operation and Maintenance Supporting References	Remarks
		Zone	Conduit	Asset ID	Asset Description	CRRF	SL-T				1. ES: Equipment/Device Security 2. DP: Data Protection 3. SA: System Administration 4. AS: Application Security 5. NS: Network Security 6. AD: Advanced Mitigation Strategies	Functional Requirements ID [FR ID-Security Measures ID-xxx]			

Table 11. The Proforma Form for the Management of the CSRS (or CRS) Traceability and Verification and Validation Matrix.

S/No.	Functional Requirements ID [FR ID-Security Measures ID-xxx]	Confirmed Security Measures/Control Measures/Countermeasures	Threat-Vulnerability ID	Verification and Validation Evidence Reference				Resolution Status [Open, Open with Design Verification Completed (ODVC), Closed, Deleted]	Remarks
		1. ES: Equipment/Device Security 2. DP: Data Protection 3. SA: System Administration 4. AS: Application Security 5. NS: Network Security 6. AD: Advanced Mitigation Strategies		Verification	Stage	Validation	Stage		

6.0 Appendix 附件

附件 A：安全風險評鑑流程 Appendix A: Security Risk Assessment Process

A.1 概述 Overview

This appendix provides a process, along with guidance, to help organizations meet the following expectations:

1. A structured process is applied to identify the threats and ensure that the security risks arising from the IACS assets defined by IEC 62443 standards and operations are systematically assessed.
2. Risk reduction/control measures/security countermeasures/security compensating countermeasures are identified and implemented, using a hierarchy of control, such as the so-called bowtie methods, to manage the identified risks to a tolerable level.
3. A tolerable level of security risk is defined for all risks impacting on safety, finance and operational functionality and is consistently understood and applied throughout a Secure SI/SM Project lifecycle.
4. Risk assessments are conducted for:
   (1) New secure System or IACS Automation Solution developments;
   (2) A secure System or IACS Automation Solution and its SuC and/or EUC;
   (3) A Secure System or IACS Automation Solution ongoing operations by Asset Owners/SuC Users; and
   (4) Security risk assessment of changes caused by activities such as SM, DM, and/or Security Update Management (SUM).
5. Cyberattack consequences evaluation consider risk on an IACS include, but are not limited to:
   (1) Endangerment of public or employee safety or health;
   (2) Damage to the environment;
   (3) Damage to the EUC;
   (4) Loss of System or IACS Automation Solution integrity;
   (5) Loss of public confidence or company reputation;
   (6) Violation of legal or regulatory requirements;
   (7) Loss of proprietary or confidential information;
   (8) Financial loss; and
   (9) Impact on entity, local, state, or national security.
6. Security risk assessments are carried out by competent personnel with appropriate independence.
7. Security risk assessments take into account learnings from security incidents from both inside and outside the organization.
8. Comply IEC 62443-3-2 and IEC 62443-3-3/IEC 62443-4-2 standards to establish requirements for:
   (1) Defining the SuC for an IACS;
   (2) Partitioning the SuC into zones and conduits;
   (3) Assessing risk for each zone and conduit;
   (4) Establishing the SL-T for each zone and conduit; and

(5) Documenting the security requirements.

A.2 設定和規劃安全風險評鑑活動 Set-up and Plan a Security Risk Assessment Activities

The security risk assessment task is based on the requirements specified in reference document – the SI/SM Project and System Security Management Guideline and the organization's related risk assessment and management processes and requirements. It should be compatible with the requirements of the IEC 62443-3-2 standard, the requirements specified by stakeholders, or a System or IACS Automation Solution applications domain-specific applicable standards or recommended practices to plan related processes, activities, or tasks.

Security risk assessment should be carried out with a structured, systematic and logical scientific methodology. The correctness, completeness, transparency, and reproducibility of the assessment results should be ensured.

The setting and planning of security risk assessment activities and/or tasks should include at least the following steps:

1. Identify and appoint responsible persons and define delegated authorities for decision making
2. Identify and appoint persons who will have defined roles and responsibilities for each aspect of the arrangements for leadership, commitment and responsibility to define roles and responsibilities and delegated authorities for decision making.
3. The senior accountable person, typically a Project Manager, PJS Leader, PDS Leader, or Systems or IACS Automation Solutions SI/SM engineering department, division, BU or P/SSO Leader, should ensure that accountabilities and responsibilities are assigned for each step in a security risk assessment process.
4. A typical risk assessment team can be composed of teams with the following Subject Matter Expert:
   (1) Senior technical personnel in a System or IACS Automation Solution assessment, implementation, and O&M;
   (2) SuC application and/or EUC operation and maintenance personnel;
   (3) Security technology experts; and
   (4) Risk assessment expert.
   (5) Risk assessment related studies or review meetings should be held by a formal meeting, assigning a chairman and recording secretary when appropriate, and under the well-established ground rules and assumptions for such kind of meetings to conduct brainstorming studies.
5. Ensure competence of appointed responsible persons.
6. The senior accountable person, typically a Project Manager, PJS Leader, PDS Leader, or Systems or IACS Automations SI/SM engineering department, division, BU or P/SSO Leader, should ensure that the required competencies are defined and agreed for all persons with assigned roles and responsibilities within the element and that each of these people is trained and coached appropriately to develop these required competencies.
7. Define risk assessment method and calibrate risk matrices.

8. The following objectives should be defined, fulfilled, or ensured by:
   (1) Ensure consistent method for security risk assessment;
   (2) Ensure consistent calibration and understanding of security risk levels;
   (3) Define required frequency for routine review and update of security risk assessments; and
   (4) Review and approve approach and calibration of security risk matrices or alternative security risk rating method.
   (5) The senior accountable person, typically a Project Manager, PJS Leader, PDS Leader, or Systems or IACS Automations engineering department, division, BU or P/SSO Leader, should ensure that the organization decides upon the method(s) that will be used to carry out their security risk assessments. They should also decide upon the approach they will adopt to ensure that there is a consistent basis for evaluating the level of security risk and ensuring that there is a consistent understanding of what level of security risk the organization considers to be tolerable and what is considered to be intolerable.
   (6) A security risk matrix provides a simple, effective, and easily understandable way to provide a consistent basis for evaluating the level of security risk and ensuring that there is a consistent understanding of what level of security risk the organization considers to be tolerable. A typical example for setting-up the tolerability of security risk for a System or IACS Automation Solution is given below for reference.
9. Develop structured register of a secure System or IACS Automation Solution.
10. The senior accountable person, typically a Project Manager, PJS Leader, PDS Leader, or Systems or IACS Automation Solutions SI/SM engineering department, division, BU or P/SSO Leader, should ensure that the organization has comprehensive structured registers in places listing all the secure System or IACS Automation Solution, of its SuC and relevant EUC application environments and/or applications.
11. Identify and prioritize required risk assessments.
12. The senior accountable person, typically a Project Manager, PJS Leader, PDS Leader, or Systems or IACS Automation Solutions SI/SM engineering department, division, BU or P/SSO Leader, should ensure that the structured register of a secure System or IACS Automation Solution is reviewed in order to identify the required security risk assessments categories or types, priority, purpose and scope, and the depth of the security analysis or study and to identify the order in which they need to be developed.
13. Plan and schedule development of required security risk assessments.
14. The senior accountable person, typically a Project Manager, PJS Leader, PDS Leader, or Systems or IACS Automation Solutions SI/SM department, division, BU or P/SSO Leader, should ensure that a plan and schedule are generated for the development of the required security risk assessments.
15. The approved plan and schedule for development of required security risk assessments covering the following as a minimum:
   (1) What will be done?
   (2) The depth and rigour required for each of the security risk assessments.

(3) When it will be done?
(4) The resource assigned to the assessment or study.
(5) Responsibility for delivery of the security risk assessments.
(6)

A.3 工作流程圖和安全風險評估要求 Workflow Diagram and Requirements of Security Risk Assessment

The following content is mainly based on the workflow and requirements specified in IEC 62443-3-2.

A.3.1 高階網宇安全風險評鑑工作流程圖、任務、輸入與輸出 Workflow Diagram, Tasks, Inputs and Outputs of a HLCRA

The workflow diagram, tasks, inputs, and outputs of a HLCRA given by IEC 62443-3-2 is shown in Figure A.1 and Table A.1 .

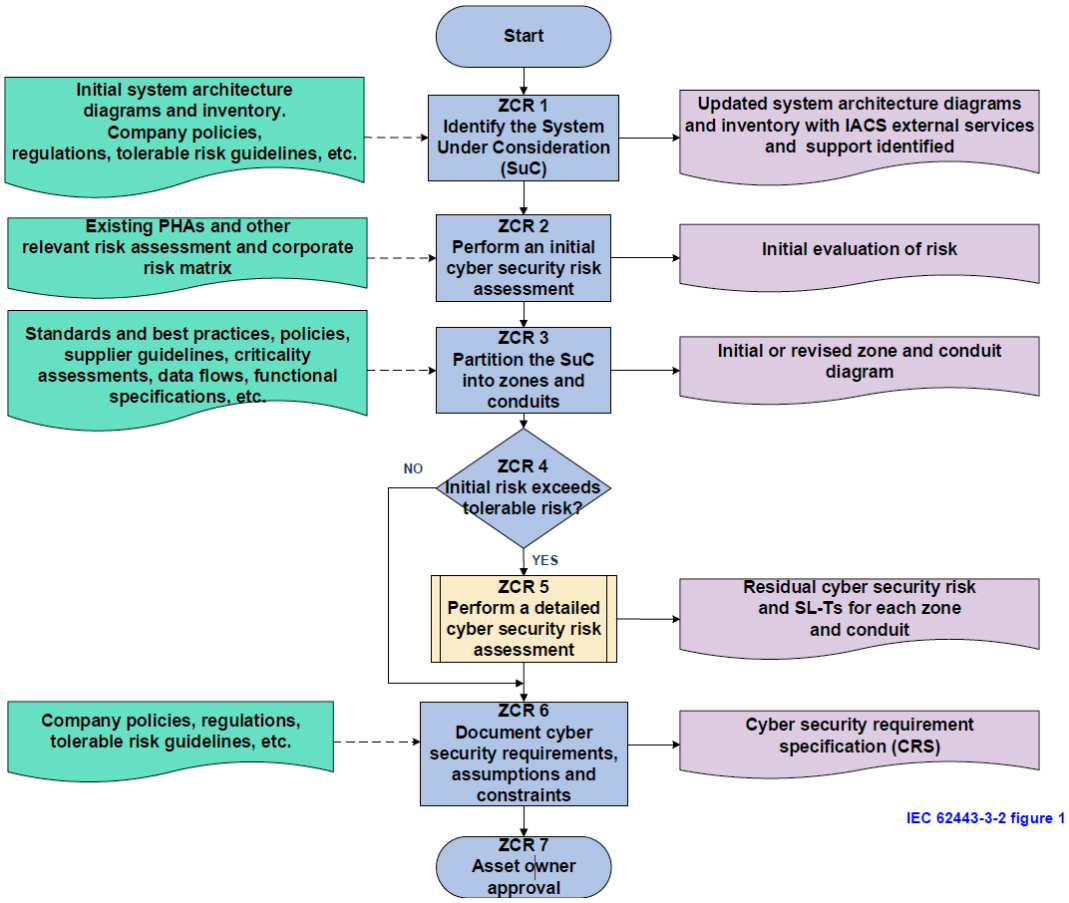


Figure A.1 The Workflow Diagram, Tasks, Inputs and Outputs of a HLCRA (IEC 62443-3-2 Figure 1).

Table A.1 The Tasks, Inputs and Outputs of a HLCRA.

Step	Task Description		Inputs	Outputs
ZCR 1	**Identify the SuC**		**Initial system architecture diagrams and inventory Company policies, regulations, tolerable risk guidelines, etc.**	**Updated system architecture diagrams and inventory with IACS external services and support identified**
	ZCR 1.1	Identify the SuC perimeter and access points	**Requirements**	
			Shall clearly identify the SuC, including clear demarcation of the security perimeter and identification of all access points to the SuC.	
ZCR 2	**Initial cyber security risk assessment**		**Existing PHAs and other relevant risk assessment and corporate risk matrix**	**Initial evaluation of risk**
	ZCR 2.1	Perform initial cyber security risk assessment	**Requirements**	
			Shall perform a cyber security risk assessment of the SuC or confirm a previous initial cyber security risk assessment is still applicable in order to identify the worst case unmitigated cyber security risk that could result from the interference with, breach or disruption of, or disablement of mission critical IACS operations.	
ZCR 3	**Partition the SUC into zones and conduits**		**Standards and best practices, policies, supplier guidelines, criticality assessments, data flows, functional specifications, etc.**	**Initial or revised zone and conduit diagram**
	ZCR 3.1	Establish zones and conduits	**Requirements**	
			Shall group IACS and related assets into zones or conduits as determined by risk. Grouping shall be based upon the results of the initial cyber security risk assessment or other criteria, such as criticality of assets, operational function, physical or logical location, required access (for example, least privilege principles) or responsible organization.	
	ZCR 3.2	Separate business and IACS assets	**Requirements**	
			IACS assets shall be grouped into zones that are logically or physically separated from business or enterprise system assets.	
	ZCR 3.3	Separate safety related assets	**Requirements**	
			Safety related IACS assets shall be grouped into zones that are logically or physically separated from zones with non-safety related IACS assets. However, if they cannot be separated, the entire zone shall be identified as a safety related zone.	
	ZCR 3.4	Separate temporarily connected devices	**Recommendation**	
			Devices that are permitted to make temporary connections to the SuC should be grouped into a separate zone or zones from assets that are intended to be permanently connected to the IACS.	
	ZCR 3.5	Separate wireless devices	**Recommendation**	
			Wireless devices should be in one or more zones that are separated from wired devices.	
	ZCR 3.6	Separate devices connected via external networks	**Recommendation**	
			Devices that are permitted to make connections to the SuC via networks external to the SuC should be grouped into a separate zone or zones.	
ZCR 4	**Risk comparison**			
	ZCR 4.1	Compare initial risk to tolerable risk	**Requirements**	
			The initial risk determined in ZCR 2 shall be compared to the organization's tolerable risk. If the initial risk exceeds the tolerable risk, the organization shall perform a detailed cyber security risk assessment as defined in ZCR 5.	
ZCR 6	**Document cyber security requirements, assumptions, and constraints**		**Company policies, regulations, tolerable risk guidelines, etc.**	**Cyber security requirements specification (CSRS or CRS)**
	ZCR 6.1	Cyber security	**Requirements**	

Step	Task Description		Inputs	Outputs
		requirements specification	CSRS or CRS shall be created to document mandatory security countermeasures of the SuC based on the outcome of the detailed risk assessment as well as general security requirements based upon company or site-specific policies, standards, and relevant regulations. At a minimum, the CSRS or CRS shall include the following: • ZCR 6.2: SUC description; • ZCR 6.3: Zone and conduit drawings; • ZCR 6.4: Zone and conduit characteristics; • ZCR 6.5: Operating environment assumptions; • ZCR 6.6: Threat environment; • ZCR 6.7: Organizational security policies; • ZCR 6.8: Tolerable risk; and • ZCR 6.9: Regulatory requirements.	
	ZCR 6.2	SuC description	**Requirements** A high-level description and depiction of the SuC shall be included in the CSRS or CRS. At a minimum, the CSRS or CRS shall include the name, a high-level description of the function and the intended usage of the SuC, as well as a description of the equipment or process under control.	
	ZCR 6.3	Zone and conduit drawings	**Requirements** Shall a) Produce a drawing or a set of drawings that illustrates the zone and conduit partitioning of the entire SuC; b) Assign each asset in the SuC to a zone or a conduit.	
	ZCR 6.4	Zone and conduit characteristics	**Requirements** The following items shall be identified and documented for each defined zone and conduit: • Name and/or unique identifier (ID); • Accountable organization(s); • Definition of logical boundary; • Definition of physical boundary, if applicable; • Safety designation; • List of all logical access points; • List of all physical access points; • List of data flows associated with each access point; • Connected zones or conduits; • List of assets and their classification, criticality and business value; • SL-T; • Applicable security requirements; • Applicable security policies; and • Assumptions and external dependencies.	
	ZCR 6.5	Operating environment assumptions	**Requirements** The CSRS or CRS shall identify and document the physical and logical environment in which the SuC is located or planned to be located.	
	ZCR 6.6	Threat environment	**Requirements** The CSRS or CRS shall include a description of the threat environment that impacts the SuC. The description shall include the source(s) of threat intelligence and include both current and emerging threats.	
	ZCR 6.7	Organizational security policies	**Requirements** Security countermeasures and features that implement the organizational security policies shall be included in the CSRS or CRS.	
	ZCR 6.8	Tolerable risk	**Requirements** The organization’s tolerable risk for the SuC shall be included in the CSRS or CRS	

Step	Task Description		Inputs	Outputs
	ZCR 6.9	Regulatory requirements	**Requirements** Any relevant cyber security regulatory requirements that apply to the SUC shall be included in the CSRS or CRS.	
ZCR 7	Asset owner approval			
	ZCR 7.1	Attain asset owner approval	Asset owner (or Secure Product Supplier, System Integration Service Provider, Maintenance Service Provider, etc. if applicable) management who are accountable for the safety, integrity and reliability of the process controlled by the SuC shall review and approve the results of the risk assessment.	

A.3.2 細部風險評鑑要求工作流程圖、任務、輸入與輸出 Workflow Diagram, Tasks, Inputs and Outputs of DRAR

The workflow diagram, tasks, inputs, and outputs of a DRAR given by IEC 62443-3-2 is shown in Figure A.2 and Table A.2.

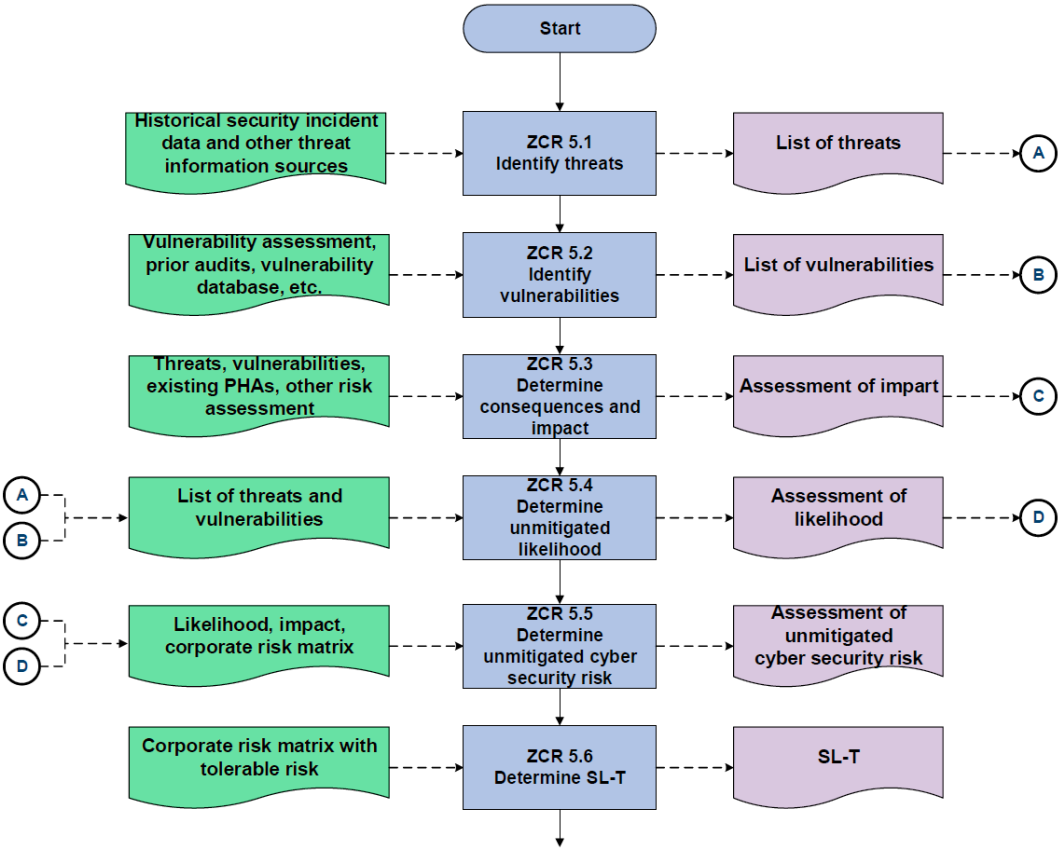


Figure A.2 The Workflow Diagram, Tasks, Inputs and Outputs of a DRAR (IEC 62443-3-2 Figure 2).

Table A.2 The Tasks, Inputs and Outputs of a DRAR.

Step	Task Description		Inputs	Outputs
ZCR 5	**Perform a detailed cyber security risk assessment**		Results of ZCR 4 when the initial risk exceeds the tolerable risk	Residual cyber security risk and SL-Ts for each zone and conduit
	ZCR 5.1	Identify threats	Historical security incident data and other threat information sources	List of threats
			Requirements	
			A list of the threats that could affect the assets contained within the zone or conduit shall be developed.	
	ZCR 5.2	Identify vulnerabilities	Vulnerability assessment, prior audits, vulnerability databases, etc.	List of vulnerabilities
			Requirements	
			The zone or conduit shall be analyzed in order to identify and document the known vulnerabilities associated with the assets contained within the zone or conduit including the access points.	
	ZCR 5.3	Determine consequence and impact	Threats, vulnerabilities, existing PHAs other risk assessments	Assessment of impact
			Requirements	
			Each threat scenario shall be evaluated to determine the consequence and the impact should the threat be realized. Consequences should be documented in terms of the worst-case impact on risk areas such as personnel safety, financial loss, business interruption and environment.	
	ZCR 5.4	Determine unmitigated likelihood	Lists of threats and vulnerabilities	Assessment of likelihood
			Requirements	
			Each threat shall be evaluated to determine the unmitigated likelihood. This is the likelihood that the threat will materialize.	
	ZCR 5.5	Determine unmitigated cyber security risk	Likelihood, impact, cooperate risk matrix	Assessment of unmitigated cyber security risk
			Requirements	
			The unmitigated cyber security risk for each threat shall be determined by combining the impact measure determined in ZCR 5.3, and the unmitigated likelihood measure determined in ZCR 5.4.	
	ZCR 5.6	Determine SL-T	Corporate risk matrix with tolerable risk	SL-T
			Requirements	
			A SL-T shall be established for each security zone or conduit.	
	ZCR 5.7	Compare unmitigated risk with tolerable risk	**Requirements**	
			The unmitigated risk determined for each threat identified in ZCR 5.5, shall be compared to the organization's tolerable risk. If the unmitigated risk exceeds the tolerable risk, the organization shall determine whether to accept, transfer or mitigate the risk. To mitigate the risk, continue to evaluate the threat by completing ZCR 5.8 through ZCR 5.12. Otherwise, the organization may document the results in ZCR 5.13 and proceed to the next threat.	
	ZCR 5.8	Identify and evaluate existing countermeasures		List of countermeasures
			Requirements	
			Existing countermeasures in the SuC shall be identified and evaluated to determine the effectiveness of the countermeasures to reduce the likelihood or impact.	
	ZCR 5.9	Reevaluate likelihood and impact	List of countermeasures (Updated)	Likelihood and impact assessment (Updated)
			Requirements	
			The likelihood and impact shall be re-evaluated considering the	

Step	Task Description		Inputs	Outputs
			countermeasures and their effectiveness.	
	ZCR 5.10	Determine residual risk	Likelihood, impact and corporate risk matrix (Updated)	Residual cybersecurity risk
			Requirements	
			The residual risk for each threat identified in ZCR 5.1 shall be determined by combining the mitigated likelihood measure and mitigated impact values determined in ZCR 5.9.	
	ZCR 5.11	Compare residual risk with tolerable risk	**Requirements**	
			The residual risk determined for each threat identified in ZCR 5.1 shall be compared to the organization's tolerable risk. If the residual risk exceeds the tolerable risk, the organization shall determine if the residual risk will be accepted, transferred, or mitigated based upon the organization's policy. Perform ZCR 5.12 and then go back to ZCR 5.9 if any residual risk is higher than tolerable risk, otherwise close the DRAR by ZCR 5.13.	
	ZCR 5.12	Identify additional cyber security countermeasures		List of countermeasures (Updated)
			Requirements	
			Additional cyber security countermeasures such as technical, administrative or procedural controls shall be identified to mitigate the risks where the residual risk exceeds the organization's tolerable risk unless the organization has elected to tolerate or transfer the risk.	
	ZCR 5.13	Document and communicate results		Detailed risk assessment report
			Requirements	
			The results of the detailed cyber risk assessment shall be documented, reported and made available to the appropriate stakeholders in the organization. Appropriate information security classification shall be assigned to protect the confidentiality of the documentation. Documentation shall include the date each session was conducted as well as the names and titles of the participants. Documentation that was instrumental in performing the cyber risk assessment (such as, system architecture diagrams, PHAs, vulnerability assessments, gap assessments and sources of threat information) shall be recorded and archived along with the cyber risk assessment.	

A.3.3 網宇攻擊或事件的可能性和衝擊評鑑 Likelihood and Impact Evaluation of Cyber Attacks or Incidents

The Impact Category evaluation method of security risks that is harmonized and applied to the security risk matrix of Figure 1 and the security risk category definition of Figure 2 can be defined by appropriate Safety, Finance, and Operational Functionality Severity Classes of Damage Categories given in Table A.3 to evaluate the impact level of cyber threats or incidents.

Table A.3 Classification for the Damage Potential (DP) Factors.

傷害類別 (Damage Category)	損壞參考 (Damage Reference)	因子 (Factor)
安全嚴重性等級 (Safety Severity Classes)	危及生命的傷害(生存不確定)，致命傷害 Life-threatening injuries (survival uncertain), fatal injuries	10,000
	嚴重和危及生命的傷害(可能存活) Severe and life-threatening injuries (survival probable)	1,000
	輕度和中度傷害 Light and moderate injuries	100
	沒有受傷 No injuries	0

傷害類別 (Damage Category)	損壞參考 (Damage Reference)	因子 (Factor)
財務嚴重性等級 (全球總和) (Finance Severity Classes (global sum))	存在威脅的財務損失(例如，貨幣損失>年銷售額的30%) Existence-threatening financial damage (e.g., monetary damage is >30% of annual sales)	1,000
	大量財務損失，但尚未存在威脅(例如，貨幣損失是年銷售額的20%-30%) Substantial financial damage, but yet not existence-threatening (e.g., monetary damage is 20%-30% of annual sales)	100
	不良的財務損失(例如，貨幣損失是年銷售額的5%-20%) Undesirable financial damage (e.g., monetary damage is 5%–20% of annual sales)	10
	沒有或可容忍的財務損失(例如，貨幣損失<年銷售額的5%) No or tolerable financial damage (e.g., monetary damage is <5% of annual sales)	0

傷害類別 (Damage Category)	損壞參考 (Damage Reference)	因子 (Factor)
營運功能性嚴重性等級 (Operational Functionality Severity Classes)	系統不可用，即一個或多個基本功能受到影響 System unusable, i.e. one or more fundamental functions are affected	100
	需要維修或維護，即重要功能受到影響， 該系統只能在大量限制下使用 Service or maintenance required, i.e. an important function is affected. The system can be used only with massive restrictions.	10
	舒適或操作受到影響，即功能受到影響，該系統可以在一些限制下使用 Comfort or operation affected, i.e. a function is affected. The system can be used with some restrictions.	1
	沒有相關的影響，即至多不重要的功能受到影響，並且可以無限制地使用該系統 No relevant effect, i.e. at most, an unimportant function is affected and the system can be used without restrictions.	0

The total DP can then be calculated by estimating and adding the values of the three individual factors: $DP_{total} = DP_{safety} + DP_{finance} + DP_{operation}$.
Afterward, the total DP can be translated into four Impact categories ready to be used for the risk calculations. Table A.4 defines this translation and gives the categories of likely severity of the attacks.

Table A.4 Impact Category Translation and Categories Definition for the Severity of the Attacks.

總損傷潛力(DP_{total})	衝擊性類別(Impact Category)
0 – 2	輕微的(Minor)
3 – 21	中度的(Moderate)
22 – 210	重大的(Major)
> 210	關鍵的(Critical)

Note that this is only an example, derived from a specific version of ETSI TS 102 165-1. When using it, you should update to the latest version, or adopt other best practices, and adjust and redesign appropriately.

Table A.5 Attack Potential (AP)

因子(Factor)	範圍(Range)	數值(Value)
知識 Knowledge	公開的 (Public)	0
	受限的 (Restricted)	1
	敏感的 (Sensitive)	4
	關鍵的 (Critical)	10
機會 Opportunity	不必要/無限制存取/訪問 (Unnecessary/unlimited access)	0
	簡單的 (Easy)	1
	中等的 (Moderate)	4
	困難的 (Difficult)	12
	沒有 (None)	攻擊路徑無法開拓 (Attack path is not exploitable)

因子(Factor)	範圍(Range)	數值(Value)
設備 Equipment	標準的 (Standard)	0
	專門的 (Specialized)	3
	定製的 (Bespoke)	7

因子(Factor)	範圍(Range)	數值(Value)
進行攻擊的時間 Time to perform an attack 每週1點 (1 point per week)	=< 1 天 (=< 1 day)	0
	= < 1 週 (=< 1 week)	1
	=< 1 個月 (=< 1 month)	4
	=< 3 個月 (=< 3 months)	13
	=< 6 個月 (=< 6 months)	26
	>6 個月 (> 6 months)	攻擊潛力超出預期 (Attack potential is beyond high)
專業知識 Expertise	外行 (Layman)	0
	精通 (Proficient)	2
	專家 (Expert)	5

Calculation of the likelihood of the attacks is made with the addition of all Attack Potential factors: $AP_{total} = AP_{time} + AP_{expertise} + AP_{knowledge} + AP_{opportunity} + AP_{equipment}$.

Resulting AP value is then mapped to the likelihood levels and is defined in Table A.6.

Table A.6 Categories Definition for the Frequency of Occurrence of the Attacks.

AP數值 (AP Value)	AP水準 (AP Level)	概率/可能性水準 (Likelihood Level)
<3	沒有評等(No rating)	必然的 (Certain)
3-6	基本的 (Basic)	容易的 (Likely)
7-14	中等的 (Moderate)	可能的 (Possible)
15-26	高的(High)	不太可能的 (Unlikely)
>26	超高的 (Beyond high)	罕見的 (Remote)

Note that this is only an example, derived from a specific version of ETSI TS 102 165-1. When using it, you should update to the latest version, or adopt other best practices, and adjust and redesign appropriately.

A.3.4 安全目標和 SL 之間的鏈接 Linkage between Security Objectives and SLs

An SL-T of a secure System or IACS Automation Solution is which a Zone with the highest SL-T requirement exists in all Zones of the System or IACS Automation Solution. It is the most critical security/cybersecurity Zone of the System or IACS Automation Solution. A Cyber Risk Reduction Factor (CRRF) is suggested to allocate or determine (or specify) the SL-T of each Conduit in each Zone through a Risk Classification Matrix defined in Figure 1 and Figure2

The CRRF can be obtained by allocating unmitigated risk with the necessary risk reduction methods, countermeasure, or treatments to reduce to the risk into or lower than the Tolerable risk level. The CRRF value is equal to a $R_{unmitigated}$ Value being divided by the Value of a Tolerable Risk Target. Figure A.3 gives an example of the mapping of a CRRF value to a specific SL-T.

$R_{unmitigated}$ Value	CRRF	SL-T	$R_{unmitigated}$ Value	CRRF	SL-T
1	0.33	0	11	3.67	3
2	0.67	0	12	4.00	3
3	1.00	0	13	4.33	4
4	1.33	1	14	4.67	4
5	1.67	1	15	5.00	4
6	2.00	1	16	5.33	4*
7	2.33	2	17	5.67	4*
8	2.67	2	18	6.00	4*
9	3.00	2	19	6.33	4*
10	3.33	3	20	6.67	4*

Note: *Advanced risk assessments or evaluation techniques should be adopted.

Figure A.3 Example for the Mapping of a CRRF Value to a Specific SL-T

A.3.5 不同的 SL 和/或 SL-C 成分 Different SLs and/or SL-C Constituents

SLs-C are the security levels that systems (based on IEC 62443-3-3) or components (based on IEC 62443-4-2) can provide when properly configured. These levels state that a particular system or component is capable of meeting the SL-T natively without additional compensating countermeasures.

While SLs are a measure of the strength of technical requirements, MLs are a measure of processes (people, policies, and procedures). IEC 62443-2-1, IEC 62443-2-2, and IEC 62443-2-4 use MLs to measure how thoroughly requirements are met. SL-C is the key criteria and covers security functionalities and processes. A methodology to evaluate the SL-C or the required protection level is to combine both evaluation results from MLs and SLs.

Figure A.4 provides an SL-verification or SL-C evaluation methods for automation solutions based on ISA 99-62443-2-2 draft for comments standard.

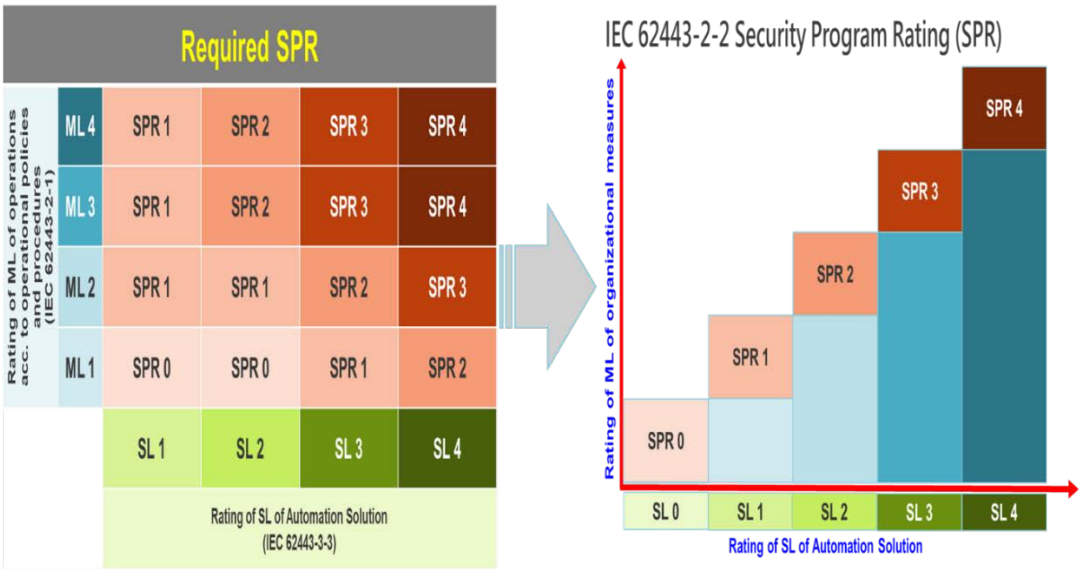


Figure A.4 SL-verification or SL-C Evaluation Methods for Automation Solutions.

A.3.6 與技術安全要求的鏈接 Linkage to Technical Security Requirements

The technical security requirements of IACS systems based on SLs are specified in IEC 62443-3-3. The principal audience include Product Suppliers of IACS systems, control systems, automation solutions, System Integration Service Provider, Maintenance Service Provider, and Asset Owners.

The technical security requirements of IACS components based on SLs are specified in IEC 62443-4-2. The IACS components include Embedded Devices, Host Devices, Network Devices, and Software Applications. The principal audience is for the Product Supplier of IACS components.

Recommend security risk reduction/control measures/security countermeasures/security compensating countermeasures through cybersecurity risk assessment should fully consider the seven (7) categories of FRs defined in the IEC 62443 standard, i.e. FR 1-IAC, FR 2, UC, FR 3-SI, FR 4- DC, FR 5-RDF, FR 6-TRE,

and FR 7-RA, and technical security requirements provided in IEC 62443-3-3 and IEC 62443-4-2 standards to propose appropriate risk control recommendations.
In addition, in order to effectively manage risk control measures and the risk control results of cyber threats, in practice, relevant risk reduction/control measures/security countermeasures/security compensating countermeasures can be further managed by the following group classifications for V&V management:

1. ES: Equipment/Device Security;
2. DP: Data Protection;
3. SA: System Administration;
4. AS: Application Security;
5. NS: Network Security; and
6. AD: Advanced Mitigation Strategies.

A.4 設定和規劃安全風險評鑑活動 Set-up and Plan a Security Risk Assessment Activities

The activities and tasks regarding monitor, review and management Intervene, such as the following:

1. performance measurement and compliance checking;
2. performance and compliance trend analysis;
3. annual review of effectiveness and sustainability of threats identification and security risk assessment arrangements; and
4. management review and control meetings,
5. should be planned appropriately in accordance with the requirements specified in reference document –the SI/SM Project and System Security Management Guideline and the organization's related risk assessment and management processes and requirements.

7.0 Reference

[1] A17-M600-CM20-01 專案管理程序 || QMS-01 品質手冊 第 8 章營運 和 QP-03 客戶需求管理程序

[2] A17-M732-CM20-01 設計管理程序 ||QP-14 設計管制程序

[3] A17-M720-CM20-01 工程規劃執行與驗收管理程序 ||QP-11 產品檢驗管理程序

[4] A17-P300-EHS20-11 事故、不符合與矯正措施管理程序

[5] TAICS TR-0023 v1.0 智慧製造工業自動化控制系統資安指引-第一部:資產擁有者

[6] TAICS TR-0027 v1.0 智慧製造工業自動化控制系統資安指引–第二部：整合和維護服務提供者

[7] TAICS TR-0031 v1.0 智慧製造工業自動化控制系統資安指引-第三部產品供應商之製造系統網宇安全

[8] XXX-XXXX-XXXXX-XX 整合/維護服務專案和系統安全管理指南(SI/SM Project and System Security Management Guideline)

[9] CLC TS 50701 - Cybersecurity for railway applications

[10] EN 50126-2 Railway applications - The specification and demonstration of Reliability, Availability, Maintainability and Safety (RAMS) - Part 2: Systems approach to safety

[11] ETSI TS 102 165-1 CYBER; Methods and protocols; Part 1: Method and pro forma for Threat, Vulnerability, Risk Analysis (TVRA)

[12] IEC 61508 Functional safety of electrical/electronic/programmable electronic safety-related systems

[13] IEC 62443-2-1 ED2 Security for industrial automation and control systems - Part 2-1: Security program requirements for IACS asset owners

[14] IEC 62443-2-2 ED1 Security for industrial automation and control systems - Part 2-2: IACS Security Protection

[15] IEC 62443-2-4 Security for industrial automation and control systems - Part 2-4: Security program requirements for IACS service providers

[16] IEC 62443-3-2 Security for industrial automation and control systems - Part 3-2: Security risk assessment for system design

[17] IEC 62443-3-3 Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels

[18] IEC 62443-4-1 Security for industrial automation and control systems - Part 4-1: Secure product development lifecycle requirements

[19] IEC 62443-4-2 Security for industrial automation and control systems - Part 3-2: Security risk assessment for system design

[20] IEC Guide 116 Guidelines for safety related risk assessment and risk reduction for low voltage equipment

[21] IEC Guide 120 Security aspects – Guidelines for their inclusion in publications

[22] IEC PAS 63325 Lifecycle requirements for functional safety and security for IACS

[23] IEC TR 63069 Industrial-process measurement, control, and automation - Framework for

functional safety and security (TS 63069 Underdevelopment)

[24] IEC TS 63074 Safety of machinery - Security aspects related to functional safety of safety-related control systems

[25] ISA-TR84.00.09 Cybersecurity related to the functional safety lifecycle

[26] ISO 13485 Medical devices – Quality management systems – Requirements for regulatory purposes

[27] ISO 22163 Railway applications – Railway quality management system – ISO 9001:2015 and particular requirements for application in the rail sector

[28] ISO 29001 Petroleum, petrochemical and natural gas industries – Sector-specific quality management systems – Requirements for product and service supply organizations

[29] ISO 9001 Quality management system

[30] ISO/IEC 18974 Information technology - OpenChain security assurance specification

[31] ISO/IEC 5230 Information technology – OpenChain Specification

[32] ISO/IEC 5962 Information technology – SPDX® Specification V2.2.1

[33] ISO/SAE 21434 Road vehicles - Cybersecurity engineering

[34] ENISA: Guidelines for Securing the Internet of Things - Secure supply chain for IoT (2020)

[35] Executive Order (EO) 14017 America's Supply Chains (2021)

[36] Executive Order (EO) Improving the Nation’s Cybersecurity (2021)

[37] SAE J 3061 Cybersecurity guidebook for cyber-physical vehicle systems

[38] US DOC – NTIA The Minimum Elements for a Software Bill of Materials (SBOM) (2021)

[39] US DOD: EO 14017 REPORT - Securing Defense-Critical Supply Chains (2022)

--- End of Document ---